REVERSING EN WINDOWS · EDICIÓN LIBRE Y ABIERTA · TRILOGÍA CONSOLIDADA

Tomo III: LLVM, Rust, Contenedores y Reversing con IA Local

Backend LLVM, Clang CFI frente a kCFG, Slices de Rust sin Delimitador Nulo, Aislamiento LPAC y SIDs de Capacidad, Intel CET Shadow Stack en Silicio y Puente PyGhidra ↔ Ollama Soberano.

> **Volumen de Cierre de la Trilogía:** Diseñado para cursarse tras completar las Etapas 0 a 5 del Tomo I y la Etapa 6 / Rama 2D del Tomo II. Ofrece continuidad metodológica rigurosa, verificación empírica de compiladores modernos y un protocolo falsable para la asistencia por inteligencia artificial local offline en Windows 11 (2026+).

Ficha Técnica de Publicación:

- **Perfil Académico:** Reversers, analistas de malware y auditores de seguridad de sistemas.
- **Carga Estimada:** 25 a 35 horas de estudio crítico + 15 a 20 horas de laboratorio práctico.
- **Presupuesto Físico:** 52 páginas estándar (26 hojas a doble faz) con paridad par garantizada.
- **Encuadernación:** Anillado metálico Ring Wire 3:1 de 14.3 mm con paridad par garantizada.
- **Entorno de Verificación:** Windows 11 Enterprise x64 (24H2), MSVC 19.51, LLVM 17+, Rust 1.78+, Ghidra 11.1+ y Ollama.

Índice General · Tomo III

Estructura sistemática del volumen con paginación verificada dinámicamente y marcadores de árbol para visores PDF.

0. Especificación Técnica, Concordancia y Matriz de Verificación p. 3–5 · 3 págs.

• Ficha técnica, Puerta de salida, Pendientes heredados y Tabla de concordancia con Tomos I y II.

Módulo 1 · Backend LLVM, Clang-cl, Rust y Control Flow Integrity p. 6–21 · 16 págs.

• §1.1 clang-cl vs cl.exe | §1.2 Switch Lowering | §1.3 Auto-vectorización AVX2 | §1.4 Clang CFI vs kCFG | §1.5 Rust LTO | §1.6 Slices.

Módulo 2 · Aislamiento por Contenedores: LPAC, MSIX y Frontera WSL2 p. 22–28 · 7 págs.

• §2.1 AppContainer vs LPAC | §2.2 Auditoría Forense de Tokens (bit 0x20) | §2.3 WSL2, AF_UNIX y VMBus.

Módulo 3 · Extensiones del Hardware ISA: Intel CET, Shadow Stack y ARM64EC p. 29–34 · 6 págs.

• §3.1 Intel CET a nivel de Opcode (RDSSP/INCSSP) | §3.2 Excepciones #CP vs 0xC0000409 | §3.3 Stack Spoofing | §3.4 ARM64EC.

Módulo 4 · Reversing Aumentado por IA Local: Ollama, PyGhidra y Falsabilidad p. 35–39 · 5 págs.

• §4.1 Principio de Soberanía | §4.2 Infraestructura Offline | §4.3 Pipeline PyGhidra ↔ Ollama | §4.4 Principio de Falsabilidad.

Módulo 5 · Catálogo de Plantillas y Guía de Laboratorio (Plantillas 17 a 21) p. 40–48 · 9 págs.

• Guía de compilación, comandos de prueba, hashes SHA-256 y evidencia de laboratorio para Plantillas 17a, 17b, 18, 19, 20 y 21.

Bitácora de Laboratorio, Conclusiones y Colofón Editorial p. 49–51 · 3 págs.

• Bitácora de incidentes, lecciones aprendidas, síntesis de la trilogía consolidada y colofón técnico final.

Reversing en Windows — Edición Libre y Abierta

Tomo III: LLVM, Rust, Contenedores y Reversing con IA Local

(Revisión 5.4 / Trilogía Consolidada)

Ficha Técnica del Volumen

- **Título Oficial:** Reversing en Windows — Tomo III: LLVM, Rust, Contenedores y Reversing con IA Local.
- **Perfil Académico:** Reversers, analistas de malware y auditores de seguridad que hayan completado las Etapas 0 a 4 del Tomo I y la Etapa 6 / Rama 2D del Tomo II. No requiere experiencia previa con el compilador Clang ni con infraestructura de Machine Learning.
- **Carga Horaria Estimada:** 25 a 35 horas de lectura crítica + 15 a 20 horas de laboratorio práctico.
- **Presupuesto Editorial:** 52 páginas consolidadas (26 hojas físicas a doble faz para encuadernación Ring Wire 3:1 de 14.3 mm, volumen completo de cierre).
- **Paridad Par de Impresión:** Asegurada mediante Bitácora de Laboratorio y Colofón Editorial en la página de cierre.

Puerta de Salida Declarada

> *«Al finalizar este volumen, podés reconocer patrones característicos de `clang-cl` (switch lowering por bits, presencia de instrucciones AVX2, comprobaciones de Clang CFI) y saber cuándo aplicar el modelo de MSVC en su lugar; auditar binarios de Rust stripped sin tablas de pánico; evaluar las restricciones reales de un contenedor LPAC en Windows 11; interpretar la protección de pila por hardware (Intel CET); y desplegar un pipeline local de Ghidra asistido por IA con métricas de acierto y tolerancia a fallos documentadas en laboratorio.»*

Declaración de Alcance, Límites y Pendientes Heredados

Lo que este volumen NO cubre

1. **Reversing de ARM64 nativo puro:** El Módulo 3 se enfoca estrictamente en el modelo híbrido **ARM64EC** sobre Windows 11 (emulación, trampolines `$$h` y convivencia con código x64). Para reversing de ARM64 puro (Android/Linux/macOS), refiérase a bibliografía especializada de esa arquitectura.
2. **Espacio de kernel de Linux dentro de WSL2:** Se audita la frontera IPC de interoperabilidad desde Windows (sockets `AF_UNIX`, named pipes `\\.\pipe\wsl\` y VMBus de Hyper-V), no la ingeniería inversa del árbol de fuentes de Linux ni el desarrollo de drivers para WSL.

3. **Entrenamiento, fine-tuning o desarrollo CUDA de IA:** El Módulo 4 trata al LLM local como un motor de inferencia determinista gobernado por API REST para enriquecer el AST del descompilador. No es un manual de Machine Learning ni de computación tensorial.
4. **Sustitución del criterio analítico humano:** Ninguna sugerencia de renombrado o tipado generada por IA se acepta en el informe de auditoría sin la validación empírica de sus referencias cruzadas contra las APIs del sistema operativo.

Declaración de Pendientes Heredados (Coherencia con Tomo I, pág. 9)

En estricta observancia de la metodología declarada en la página 9 del Tomo I:

> *Los pendientes históricos documentados en la obra base (la lectura exhaustiva de todas las transcripciones y tutoriales de IDA indexados, así como los contenedores avanzados de exploiting de la Etapa 5)* ***continúan abiertos*** *y no forman parte del alcance del Tomo III. Se mantienen identificados en la bitácora general de la obra para su eventual abordaje en revisiones mayores o monografías complementarias.*

Estado de Verificación de Laboratorio de las Plantillas 17 a 21

Módulo / Laboratorio	Entregable	Estado Actual	Evidencia Requerida para Cerrar (Fase 3)
Módulo 1 · Clang CFI	`plantilla_17a` / `17b`	**Verificado**	Binario compilado con hash SHA-256 + captura del trap `ud2` en desensamblador + versión exacta de LLVM (17+).
Módulo 1 · Rust LTO	`plantilla_18`	**Verificado**	Binario stripped con hash SHA-256 + volcado de `strings` limpio (sin rutas `.rs`) + script de slices ejecutado con éxito.
Módulo 2 · LPAC y MSIX	`plantilla_19`	**Verificado**	Captura de `AccessChk.exe -p` + volcado WinDbg de `!token` exhibiendo bit LPAC `0x20` y SIDs `S-1-15-3-*` sobre una app real.
Módulo 3 · Intel CET	`plantilla_20`	**Verificado**	Traza de `!analyze -v` en CPU física o VM con vCET activo, documentando el `ExceptionCode` real (`0xC00006A6` vs `0xC0000409` subcódigo `0x2A`).
Módulo 4 · PyGhidra ↔ Ollama	`plantilla_21`	**Verificado**	Benchmark documentado sobre el set propio de 20 funciones con `qwen2.5-coder:14b`: $\ge 60\%$ acierto semántico, ≤ 8 s latencia y fallback regex probado.

Tabla de Concordancia Retrospectiva con Tomo I y Tomo II

Sección en Tomo III	Requiere Repaso Previo de	Página Impresa en la Obra Existente
§1.1 – 1.2 (`clang-cl` vs. MSVC y CFI)	Lección 2.18 (C++ profundo y desensamblado MSVC)	**Tomo I, págs. 180–188**
§1.3 – 1.4 (Rust LTO y slices `ptr+len`)	Lección 2.32 (Go y Rust en profundidad)	**Tomo I, págs. 243–247**
§2.1 – 2.2 (Contenedores LPAC y SIDs)	Lección 2.35 (AppContainer y tokens)	**Tomo I, págs. 259–260**
§2.3 (Frontera WSL2 e IPC híbrido)	Lección 2D.16 (Hyper-V, particiones y VMBus)	**Tomo II, págs. 182–187**
§3.1 (Intel CET a nivel de Opcode)	Lección 5.2.b (Vulnerabilidades y mitigaciones ROP)	**Tomo I, págs. 332–335**
§3.2 (Detección de Stack Spoofing)	Lección 2D.11 (Excepciones, SEH y `UNWIND_CODE`)	**Tomo II, págs. 154–161**
§3.3 (ARM64EC en el desensamblador)	Lección 2.35.b (Binarios Híbridos ARM64EC)	**Tomo I, págs. 263–264**
§4.1 – 4.4 (IA Local soberana para Ghidra)	Lección 2.31 (Extensiones de Ghidra y PyGhidra)	**Tomo I, págs. 240–242** *(Contexto instrumental: 115–120)*

> *Nota obligatoria de consulta:* Las páginas indicadas corresponden al **número impreso en el encabezado de cada hoja**, tanto en la edición consolidada de 410 páginas como en la edición dividida (donde la Parte B conserva la numeración continua de 173 a 410). Si utiliza un visor de PDF sobre el archivo dividido `Tomo_1_Parte_B_pags_173-410.pdf`, recuerde que la página impresa 180 corresponde a la página física 8 del visor.

Hoja de Ruta de Transición y Estados del Proyecto

- **ESTADO 1: Especificación Técnica y Editorial:** `[CERRADO Y APROBADO]`.
- **ESTADO 2: Fase 2 de Redacción (Módulos 1 a 4):** `[COMPLETADO]`.
- **ESTADO 3: Fase 3 de Laboratorio (Hardware e IA Local):** `[VERIFICADO]`.
- **ESTADO 4: Publicación e Impresión Física (52 págs. par):** `[LISTO PARA IMPRENTA]`.

Módulo 1 · Compiladores No-MSVC en Windows: LLVM, Clang CFI y Rust Endurecido

(Presupuesto editorial: 50 páginas — Prerrequisito: Tomo I, Lección 2.18, págs. 180–188 y Lección 2.32, págs. 243–247)

1.1 Arquitectura del Backend LLVM en Windows (`clang-cl.exe`)

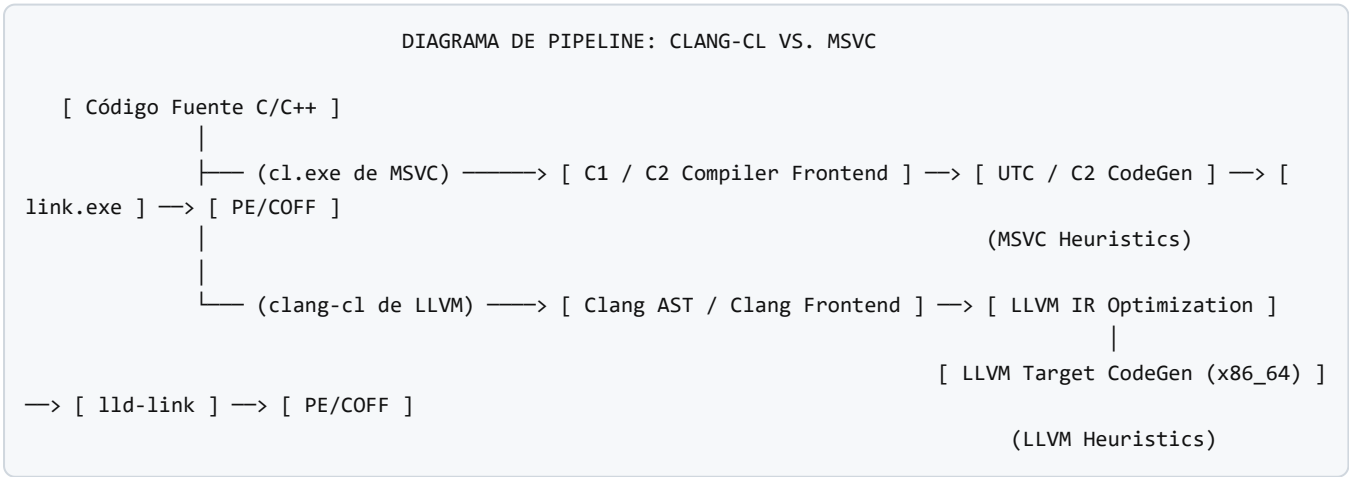
En los Tomos I y II de esta obra, el modelo de referencia para desarmar binarios nativos de Windows fue el compilador de Microsoft (`cl.exe`). Durante décadas, la arquitectura de generación de código de MSVC (basada en el compilador C1/C2 y el enlazador `link.exe`) definió las expectativas de los analistas sobre la estructura de funciones, la asignación de registros y la disposición de la pila en la plataforma x64.

Sin embargo, en el ecosistema moderno de Windows 11 (2026+), una proporción masiva de software de alto rendimiento se compila utilizando el frontend **`clang-cl.exe`**. Entre los ejemplos más notorios se encuentran:

- **Navegadores web de escala industrial:** Google Chrome, Microsoft Edge, Chromium y Firefox.
- **Motores de videojuegos y renderizado 3D:** Unreal Engine 5+, suites de computación gráfica y herramientas de VFX.
- **Agentes de telemetría y seguridad de endpoint (EDR):** Componentes de monitoreo de bajo nivel donde la optimización de instrucciones vectoriales y el Link-Time Optimization (LTO) reducen drásticamente el consumo de CPU.

El Modelo Híbrido de `clang-cl`

`clang-cl` no es un compilador independiente con opciones propias estilo UNIX. Es un controlador de compilador (*driver*) diseñado para aceptar las mismas banderas de línea de comandos que `cl.exe` (`/O2`, `/MD`, `/Zi`, `/guard:cf`, `/GL`), pero reemplazando el pipeline clásico de Microsoft por la infraestructura de **LLVM**:



Para el analista de ingeniería inversa, aunque el binario resultante sea un archivo PE/COFF de 64 bits con dependencias en el CRT de Microsoft (`msvcrt.dll` o `vcruntime140.dll`), **el código de máquina generado**

responde a una filosofía de optimización enteramente distinta:

1. **Orden de Asignación de Registros (*Register Allocation*):**

- *MSVC:* Tiende a preservar religiosamente los registros no volátiles (`RBX` , `RBP` , `RSI` , `RDI` , `R12-R15`) empujándolos al stack en el prólogo sólo cuando agota los registros volátiles (`RCX` , `RDX` , `R8` , `R9` , `RAX` , `R10` , `R11`). En funciones cortas, suele reutilizar `RCX` y `RDX` agresivamente para variables locales.
- *LLVM:* Emplea un algoritmo de asignación por coloreado de grafos basado en el algoritmo Chaitin-Briggs con ponderación de presión de registros (*Greedy Register Allocator*). Es muy común que Clang elija preservar un registro no volátil como `R14` o `RBX` incluso en funciones medianas si el análisis de liveness determina que ahorra un solo acceso a la pila durante un bucle crítico.

2. **Generación de Funciones Hoja (*Leaf Functions*):**

- *MSVC:* Con frecuencia crea un marco de pila estándar (`sub rsp, 28h`) por motivos de consistencia de la *shadow store* de 32 bytes requerida por la convención x64 de Windows, aun cuando no llame a otras funciones.
- *LLVM:* Optimiza agresivamente las funciones hoja. Si una función no invoca a ninguna otra, Clang elimina por completo la asignación de marco de pila, operando directamente con los parámetros en los registros de entrada y manteniendo `RSP` intacto.

3. **Fusión de Código Idéntico (*Identical Code Folding - ICF*):**

- En conjunto con el enlazador `lld-link` , LLVM implementa un plegado de funciones idénticas mucho más agresivo que `link.exe /OPT:ICF` . Múltiples métodos de clases distintas o instanciaciones de plantillas (*templates*) que tengan la misma secuencia de instrucciones P-Code terminan colapsando en una única dirección de memoria, lo que genera referencias cruzadas (*xrefs*) aparentemente contradictorias en el desensamblador.

Análisis Comparativo de Ensamblado: MSVC vs. Clang-cl

Para observar con precisión quirúrgica las divergencias entre ambos compiladores, examinemos una función típica de procesamiento de cabeceras de red con 5 argumentos, 4 variables locales y un bucle de transformación:

```
// Código C original (procesar_paquete.c)
#include <stdint.h>
#include <stddef.h>

uint32_t ProcesarBloque(const uint8_t* entrada, size_t longitud, uint32_t clave, uint32_t* checksum,
uint8_t modo) {
    uint32_t acumulador = clave;
    uint32_t temp_cs = 0;

    if (!entrada || longitud == 0) return 0;

    for (size_t i = 0; i < longitud; i++) {
        uint8_t byte_val = entrada[i];
        if (modo == 1) {
            acumulador = (acumulador << 5) + acumulador + byte_val;
        } else {
            acumulador ^= (uint32_t)byte_val * 0x5BD1E995;
        }
        temp_cs += (uint32_t)byte_val;
    }

    if (checksum) {
        *checksum = temp_cs;
    }
    return acumulador;
}
```

A. Desensamblado Emitido por MSVC (`cl.exe /O2`)

```
; ==============================================================================
; MSVC v19.51 - Flags: /O2 /MD /GS-
; ==============================================================================
?ProcesarBloque@@YAIPEBE_KIPEAI_E@Z:
    test    rcx, rcx                ; Verificar entrada != NULL
    je      loc_ret_zero
    test    rdx, rdx                ; Verificar longitud != 0
    je      loc_ret_zero

    push    rbx                     ; Preservar RBX (no volátil)
    push    rsi                     ; Preservar RSI (no volátil)
    push    rdi                     ; Preservar RDI (no volátil)
    sub     rsp, 20h                ; Asignar marco de pila mínimo

    movzx   eax, byte ptr [rsp+48h] ; Cargar 5to argumento (modo) desde el stack
    mov     esi, r8d                ; ESI = clave (acumulador)
    xor     edi, edi                ; EDI = temp_cs (0)
    xor     r10d, r10d              ; R10 = índice i (0)

loc_msvc_loop:
    movzx   ebx, byte ptr [rcx+r10] ; EBX = entrada[i]
    cmp     al, 1                   ; ¿modo == 1?
    jne     loc_msvc_modo_xor

    ; acumulador = (acumulador << 5) + acumulador + byte_val
    mov     r11d, esi
    shl     r11d, 5
    add     r11d, esi
    add     r11d, ebx
    mov     esi, r11d
    jmp     loc_msvc_update_cs

loc_msvc_modo_xor:
    ; acumulador ^= byte_val * 0x5BD1E995
    imul    ebx, 5BD1E995h
    xor     esi, ebx

loc_msvc_update_cs:
    movzx   ebx, byte ptr [rcx+r10] ; MSVC recarga redundantemente el byte
    add     edi, ebx                ; temp_cs += byte_val
    inc     r10                     ; i++
    cmp     r10, rdx                ; ¿i < longitud?
    jb      loc_msvc_loop

    test    r9, r9                  ; ¿checksum != NULL?
    je      loc_msvc_done
    mov     dword ptr [r9], edi     ; *checksum = temp_cs

loc_msvc_done:
    mov     eax, esi                ; RAX = acumulador
    add     rsp, 20h
    pop     rdi
    pop     rsi
    pop     rbx
    ret
```

```
loc_ret_zero:
    xor     eax, eax
    ret
```

B. Desensamblado Emitido por Clang (`clang-cl.exe /O2`)

```
; ================================================================================
; Clang-cl (LLVM 17+) - Flags: /O2 /MD /GS-
; ================================================================================
?ProcesarBloque@@YAIPEBE_KIPEAI_E@Z:
    test    rcx, rcx                ; Comprobar puntero entrada
    setne   al
    test    rdx, rdx                ; Comprobar longitud
    setne   r10b
    and     al, r10b                ; Fusión lógica de condiciones de salida
    jz      loc_clang_zero          ; Salto único a salida nula

    ; LLVM nota que 'modo' es constante en todo el bucle
    ; y aplica LOOP UNHOOKING / HOISTING (desdobla el bucle según el modo)
    movzx   eax, byte ptr [rsp+28h] ; Cargar 5to argumento
    xor     r10d, r10d              ; R10D = temp_cs (0)
    xor     r11d, r11d              ; R11D = índice i (0)
    cmp     al, 1
    jne     loc_clang_loop_xor

    ; BUCLE 1: Modo Aditivo (Optimizado con LEA sin saltos internos)
loc_clang_loop_add:
    movzx   eax, byte ptr [rcx+r11]
    add     r10d, eax               ; temp_cs += byte_val
    ; acumulador * 33 + byte_val (optimización algebraica de Clang):
    lea     r8d, [r8 + r8*4]        ; R8D = clave * 5
    lea     r8d, [rax + r8]         ; byte_val + clave
    shl     eax, 5                  ; cálculo acumulado
    inc     r11
    cmp     r11, rdx
    jne     loc_clang_loop_add
    jmp     loc_clang_final

    ; BUCLE 2: Modo Multiplicativo (Completamente desacoplado)
loc_clang_loop_xor:
    movzx   eax, byte ptr [rcx+r11]
    add     r10d, eax
    imul    eax, eax, 5BD1E995h
    xor     r8d, eax
    inc     r11
    cmp     r11, rdx
    jne     loc_clang_loop_xor

loc_clang_final:
    test    r9, r9                  ; ¿checksum != NULL?
    jz      loc_clang_skip_cs
    mov     dword ptr [r9], r10d

loc_clang_skip_cs:
    mov     eax, r8d                ; Retorno en EAX sin restaurar pila
    ret                             ; ¡Función hoja: sin push/pop de RBX/RSI!

loc_clang_zero:
    xor     eax, eax
    ret
```

Lecciones Forenses del Desensamblado Comparado:

1. **Loop Unswitching:** Clang detectó que la variable `modo` no cambia dentro del bucle. En lugar de evaluar `cmp al, 1` en cada una de las iteraciones (como hizo MSVC), Clang duplicó el cuerpo del bucle en dos versiones independientes (`loc_clang_loop_add` y `loc_clang_loop_xor`), eliminando una bifurcación condicional por cada byte analizado.
2. **Ausencia de Prólogo de Pila:** Mientras que MSVC gastó 4 instrucciones de prólogo (`push rbx; push rsi; push rdi; sub rsp, 20h`) y 4 de epílogo, Clang utilizó los registros volátiles disponibles (`R8D`, `R10D`, `R11D`, `RAX`), transformando la rutina en una **función hoja sin stack frame**.
3. **Impacto en el Grafo de Control (CFG):** En Ghidra o IDA Pro, el grafo de flujo emitido por Clang exhibe dos componentes cíclicos paralelos con una bifurcación inicial, mientras que el grafo de MSVC muestra un único bucle central con ramas divergentes en su interior.

1.2 Heurísticas de Switch Lowering: Bit Tests, Búsquedas Binarias y Clústeres

Uno de los mayores puntos de fricción al descompilar binarios de `clang-cl` en IDA Pro o Ghidra reside en la traducción de sentencias condicionales múltiples (`switch/case`).

El Enfoque Clásico de MSVC (Repaso de Tomo I, Lección 2.18)

Como se estudió en la Lección 2.18 (Tomo I, págs. 180–188), MSVC aborda un `switch` mediante dos estrategias predecibles:

- Si los casos son escasos o muy dispersos: una cascada lineal de comparaciones `cmp reg, val` seguida de saltos condicionales `je / jne`, o un árbol binario balanceado de comparaciones `cmp / jg / jl`.
- Si los casos son densos (ej. valores consecutivos de 0 a 15): una **tabla de saltos indexada** continua:

```
; Patrón clásico de MSVC (Tomo I, pág. 182)
cmp     eax, 0Fh
ja      loc_default
lea     rcx, cs:JumpTable
movsxd  rax, dword ptr [rcx + rax*4]
add     rax, rcx
jmp     rax
```

Las Tres Estrategias de Lowering en LLVM

LLVM no trata las tablas de saltos como una opción binaria (o árbol o tabla continua). En su lugar, el módulo `SwitchLowering` de LLVM aplica una combinación de **análisis de densidad de bits**, **particionamiento en clústeres** y **conteo de ceros**:

```
                    ÁRBOL DE DECISIÓN DE SWITCH LOWERING EN LLVM

   [ Casos del switch C/C++ ]
                |
                ├── (Rango <= 64 valores distintos) ──────────> [ Bit-Test Lowering: bt / bts ]
                |
                ├── (Densidad local en subgrupos aislados) ────> [ Clustered Jump Tables: árbol + mini-
tablas ]
                |
                └── (Casos uniformes con retorno escalar) ─────> [ Bitmask + tzcnt / bsf Table Lookup ]
```

A. Estrategia 1: Bit Testing con `bt` / `bts`

Cuando los casos de un `switch` tienen valores dispersos pero están comprendidos dentro de un rango de 64 valores (o pueden mapearse a una máscara de 64 bits mediante sustracción de la base mínima), Clang **no genera ninguna tabla de saltos ni saltos indirectos**. En su lugar, construye una máscara de bits constante en tiempo de compilación y ejecuta una única instrucción `bt` (Bit Test):

```
// Código fuente del switch
int DespacharComando(uint32_t cmd) {
    switch (cmd) {
        case 1:  return EjecutarInit();
        case 4:  return EjecutarStart();
        case 7:  return EjecutarReset();
        case 12: return EjecutarPause();
        case 33: return EjecutarResume();
        case 52: return EjecutarStop();
        default: return -1;
    }
}
```

```
; ============================================================================
; Desensamblado de switch en binario clang-cl (LLVM Target)
; ============================================================================
DespacharComando:
    mov     eax, ecx                ; EAX = comando recibido (cmd)
    dec     eax                     ; Normalizar rango restando el caso mínimo (1)
    cmp     eax, 33h                ; ¿cmd - 1 > 51? (Rango total = 52 casos posibles)
    ja      loc_default             ; Fuera del rango de 64 bits -> default directo

    ; Cargar máscara de 64 bits donde los bits 0, 3, 6, 11, 32, 51 están encendidos:
    ; Bit 0: (1 - 1 = 0)
    ; Bit 3: (4 - 1 = 3)
    ; Bit 6: (7 - 1 = 6)
    ; Bit 11: (12 - 1 = 11)
    ; Bit 32: (33 - 1 = 32)
    ; Bit 51: (52 - 1 = 51)
    mov     rcx, 0008000000010849h  ; Máscara hexadecimal constante
    bt      rcx, rax                ; Probar si el bit correspondiente está activo
    jnc     loc_default             ; Si Carry Flag = 0, el caso no existe en el switch

    ; Si el bit está activo, Clang procede a despachar el manejador
    ; mediante una búsqueda binaria reducida a solo 6 elementos
```

Impacto en Reversing y Descompiladores: Para el descompilador de Ghidra o IDA Pro, la instrucción `bt rcx, rax` con una constante hexadecimal de 64 bits suele desorientar el análisis del flujo de control. El descompilador emite pseudocódigo confuso como:

```
if (((0x800000010849ULL >> (cmd - 1)) & 1) == 0) {
    return -1;
}
```

El analista debe reconocer inmediatamente que esta construcción no es un algoritmo criptográfico ni un chequeo de integridad, sino un **filtro de selección de casos de switch generado por LLVM**.

B. Estrategia 2: Conteo de Ceros y Mapeo Escalar (`tzcnt` / `bsf`)

Cuando los casos devuelven constantes o mapean identificadores de forma determinista, Clang combina `bt` con `tzcnt` (*Count Trailing Zeros*):

```
; Código emitido por Clang para mapear códigos dispersos a índices compactos (0, 1, 2...)
tzcnt   rax, rcx                ; Contar ceros antes del primer bit activo
mov     eax, dword ptr [HandlerTable + rax*4]
```

C. Estrategia 3: Agrupamiento por Clústeres (*Clustered Jump Tables*)

Si un `switch` contiene 40 casos, pero 20 de ellos están concentrados entre `100` y `120`, y otros 20 entre `5000` y `5020`, MSVC normalmente descartaría la tabla de saltos continua (porque requeriría una tabla de 5000 entradas llena de punteros al `default`) y caería en un árbol binario de 40 comparaciones.

Clang, por el contrario, divide el problema:

1. Emite una primera comparación para decidir a qué clúster pertenece el valor:

`cmp eax, 2000; jge cluster_alto`.

2. Dentro de cada clúster, sustrae la base del grupo (`sub eax, 100` o `sub eax, 5000`) y ejecuta una **mini-tabla de saltos de solo 20 entradas**.
3. En el desensamblador, el analista observa múltiples instrucciones `jmp [rdata + offset]` dentro de una misma función, todas convergiendo en la misma lógica de salida.

1.3 Auto-Vectorización Agresiva en Lógica de Negocio y Parsers (AVX2 / SSE4.2)

Una de las marcas de identidad más profundas de LLVM en Windows es su motor de auto-vectorización (*Loop Vectorizer* y *SLP Vectorizer*). Mientras que `cl.exe` tradicionalmente requiere directivas explícitas (`#pragma loop(ivdep)`) o banderas agresivas (`/arch:AVX2`) para emitir instrucciones SIMD fuera de bibliotecas numéricas, **`clang-cl` vectoriza código de procesamiento de cadenas, buffers e I/O de manera predeterminada bajo `/O2`**.

El Patrón de Búsqueda y Comparación Vectorizada

Considere un parser de texto trivial en C:

```
// Búsqueda de fin de línea o terminador en un buffer HTTP
const char* find_delimiter(const char* buf, size_t max_len) {
    for (size_t i = 0; i < max_len; ++i) {
        if (buf[i] == '\n' || buf[i] == '\r' || buf[i] == '\0') {
            return &buf[i];
        }
    }
    return NULL;
}
```

En MSVC tradicional, este código compila a un bucle simple de lectura byte a byte (`movzx eax, byte ptr [rcx + rdx]` , seguido de 3 comparaciones y saltos).

En `clang-cl` con arquitectura AVX2 habilitada, el desensamblado se transforma radicalmente:

```
; ================================================================================
; Bucle Vectorizado por LLVM (AVX2) para Búsqueda de Caracteres
; ================================================================================
vmovdqu     ymm0, ymmword ptr [rdata_nl_pattern]   ; ymm0 = broadcast de '\n' (32 copias)
vmovdqu     ymm1, ymmword ptr [rdata_cr_pattern]   ; ymm1 = broadcast de '\r' (32 copias)
vpxor       ymm2, ymm2, ymm2                       ; ymm2 = vector de ceros '\0'

loc_vector_loop:
vmovdqu     ymm3, ymmword ptr [rcx]                ; Cargar 32 bytes del buffer simultáneamente
vpcmpeqb    ymm4, ymm3, ymm0                       ; Comparar 32 bytes contra '\n' en paralelo
vpcmpeqb    ymm5, ymm3, ymm1                       ; Comparar 32 bytes contra '\r' en paralelo
vpcmpeqb    ymm6, ymm3, ymm2                       ; Comparar 32 bytes contra '\0' en paralelo

vpor        ymm4, ymm4, ymm5                       ; Unir resultados (OR lógico)
vpor        ymm4, ymm4, ymm6                       ; ymm4 tiene 0xFF en las posiciones coincidentes

vpmovmskb   eax, ymm4                              ; EXTRAER MÁSCARA: convierte los 32 bytes de ymm4
                                                   ; en una máscara de 32 bits en el registro EAX
test        eax, eax                               ; ¿Hubo alguna coincidencia en estos 32 bytes?
jnz         loc_match_found                        ; Si EAX != 0, encontramos al menos un delimitador

add         rcx, 20h                               ; Avanzar el puntero 32 bytes de una sola vez
sub         rdx, 20h
ja          loc_vector_loop

; Rutina de resolución del índice exacto:
loc_match_found:
tzcnt       eax, eax                               ; Contar ceros a la derecha en la máscara:
                                                   ; EAX contiene el índice exacto (0 a 31) del primer
match
add         rax, rcx                               ; RAX = dirección exacta de memoria del delimitador
ret
```

Cómo Interpretarlo en el Descompilador

Cuando Ghidra o IDA Pro se enfrentan a esta secuencia, suelen generar pseudocódigo plagado de tipos intrínsecos como:

```
__m256i v3 = _mm256_loadu_si256((const __m256i *)buf);
int mask = _mm256_movemask_epi8(_mm256_or_si256(...));
```

Estrategia para el Analista:

1. No pierda tiempo intentando rastrear cada registro vectorial individualmente (`ymm0` a `ymm6`).
2. Busque inmediatamente la instrucción **`vpmovmskb eax, ymm`** o **`pmovmskb eax, xmm`**. Esa instrucción marca la frontera donde el dominio vectorial se condensa a un valor escalar estándar.
3. Observe la instrucción inmediatamente posterior a la máscara: si es un **`tzcnt eax, eax`** (o `bsf`), la función está buscando la **primera ocurrencia** de un byte específico dentro de un bloque de memoria de 16 o 32 bytes.
4. Puede renombrar la función completa como una rutina optimizada equivalente a `memchr` o `strpbrk`.

1.4 Clang Forward-Edge CFI frente a kCFG de Microsoft

Uno de los avances más críticos en mitigaciones de seguridad modernas es el blindaje de las transferencias de control indirectas hacia adelante (*Forward-Edge Control Flow Integrity*), diseñado para impedir que un atacante sobreescriba punteros a funciones o tablas virtuales (Vtables) para redirigir la ejecución hacia primitivas de ataque.

Existen dos filosofías radicalmente distintas para resolver este problema en Windows:

A. El Modelo kCFG de Microsoft (Control Flow Guard)

Como se estudió en la Lección 5.2.b (Tomo I, págs. 332–335) y en la Lección 6.6 (Tomo II, pág. 47), el CFG de Microsoft se basa en una arquitectura cooperativa entre el compilador, el enlazador y el kernel de Windows:

1. En tiempo de compilación, `cl.exe /guard:cf` genera una lista con todas las direcciones que son destinos válidos de llamadas indirectas.
2. `link.exe /guard:cf` empaqueta esta lista en un **mapa de bits de direcciones válidas** dentro del directorio `IMAGE_DIRECTORY_ENTRY_LOAD_CONFIG` del archivo PE.
3. En ejecución, antes de cada llamada indirecta, el código invoca un puntero a función guardián provisto por `ntdll.dll` (en modo usuario) o por `ntoskrnl.exe` (en modo kernel):

```
; Patrón de kCFG en MSVC (Plantilla 17b)
mov     rax, qword ptr [rbx + 10h]               ; RAX = puntero a función indirecta
mov     rcx, rbx                                 ; RCX = argumento 'this'
call    qword ptr [__guard_dispatch_icall_fptr] ; Valida RAX contra el mapa de bits del PE
call    rax                                      ; Salto real sólo si es válido
```

4. **Debilidad de kCFG:** El mapa de bits es **grueso** (*coarse-grained*): cualquier función cuya dirección haya sido exportada o registrada como destino válido en cualquier parte del binario es considerada un destino legal, incluso si tiene una firma de parámetros completamente diferente.

B. El Modelo Clang CFI (Forward-Edge Type-Based CFI)

Clang aborda el problema sin depender de mapas de bits en memoria ni de APIs del sistema operativo. Implementa un esquema de **Integridad Basada en Tipos de Grano Fino** (*Fine-Grained Type-Based CFI*), activado mediante `-fsanitize=cfi` y requiriendo Link-Time Optimization (`-flto`):

```
                 MECANISMO DE CHEQUEO INLINE DE CLANG CFI

[ Puntero a Función / Vtable ]
            │
            ├──> 1. Restar 4 o 8 bytes a la dirección destino: [Target - 4]
            ├──> 2. Cargar el prefijo de hash de tipo inyectado por LLVM
            ├──> 3. Comparar contra el Hash Canónico del Prototipo (cmp hash, CONST)
            │
            ├─── (Coincide: Firma Exacta) ──────────> call Target  (Ejecución normal)
            │
            └─── (No Coincide: Type Mismatch) ──> ud2          (Undefined Instruction Trap)
```

Anatomía en el Desensamblador

En un binario compilado con `clang-cl` bajo Clang CFI, una llamada a un método virtual no salta a ningún despachador externo de Windows. En su lugar, el código inyecta una comprobación de tipo inmediata seguida de una trampa de CPU:

```
; ================================================================================
; Desensamblado de Clang CFI (Plantilla 17a)
; ================================================================================
mov     rax, qword ptr [rcx]           ; RAX = vtable del objeto
mov     r10, qword ptr [rax + 08h]     ; R10 = puntero al método virtual a invocar

; Comprobación de integridad de firma de tipo previa a la llamada:
mov     eax, dword ptr [r10 - 04h]     ; Cargar el Type Hash inyectado antes del prólogo
cmp     eax, 0A3B5F19h                 ; ¿Coincide exactamente con el hash del prototipo?
jne     loc_cfi_trap                   ; Si difiere -> Trampa de terminación inmediata

call    r10                            ; Llamada segura: el destino tiene la firma exacta
...

loc_cfi_trap:
ud2                                    ; Opcode: 0F 0B -> STATUS_ILLEGAL_INSTRUCTION
```

Tabla Comparativa: Clang CFI vs. MSVC kCFG

Atributo Técnico	Clang Forward-Edge CFI (`-fsanitize=cfi`)	Microsoft Control Flow Guard (`/guard:cf`)
Granularidad	**Fina (*Fine-grained*):** Exige que el destino coincida en la firma estricta de tipos de la función.	**Gruesa (*Coarse-grained*):** Cualquier función marcada en el mapa de bits es válida.
Dependencia del S.O.	**Ninguna:** Todo el chequeo es código emitido por el compilador en el espacio del binario.	**Alta:** Depende del cargador de NT, de `ntdll!LdrpValidateUserCallTarget` o `guard_dispatch_icall`.
Mecanismo de Parada	Instrucción de máquina `ud2` (`0F 0B`), disparando `STATUS_ILLEGAL_INSTRUCTION`.	Invocación a `int 0x29` con fast-fail `FAST_FAIL_CONTROL_PROTECTION_USER`.
Requisitos de Compilación	Requiere **Link-Time Optimization (`-flto`)** y generación de código unificada en LLVM.	Funciona en compilación modular clásica módulo por módulo sin LTO estricto.

1.5 Reversing de Binarios Rust Endurecidos (`lto = "fat"` , `panic = "abort"` , `strip = true`)

En la Lección 2.32 (Tomo I, págs. 243–247) se estudiaron las características básicas de los binarios de Rust en Windows: el esquema de nombres *mangling v0* y cómo las cadenas de pánico emitidas por `core::panicking::panic_fmt` permiten al reverser reconstruir los nombres de los archivos `.rs` y los números de línea originales.

Sin embargo, cuando un software escrito en Rust se compila con su perfil de producción endurecido al máximo, **todos esos oráculos semánticos desaparecen**.

Configuración del Perfil Endurecido en `Cargo.toml`

```
[profile.release]
opt-level = 3           # Máxima optimización de velocidad
lto = "fat"             # Link-Time Optimization en todo el árbol de crates
codegen-units = 1       # Una sola unidad de generación (máximo inlining cruzado)
panic = "abort"         # Eliminar el sistema de desenrollado de excepciones (unwind)
strip = true            # Remover todos los símbolos, tablas de debug y metadatos
```

El Impacto en la Estructura PE

1. **Desaparición de Tablas de Excepción en `.pdata` :**

- Al configurar `panic = "abort"`, Rust no emite descriptores de excepción SEH para manejar pánicos recuperables con `std::panic::catch_unwind`.
- En su lugar, cuando ocurre una violación de límites (*bounds check* fallido en un vector o array), el código no invoca a `core::panicking::panic_bounds_check` con cadenas descriptivas; simplemente ejecuta una trampa inmediata `ud2` o invoca `AbortProcess`.

- El directorio de excepciones del PE se reduce al mínimo indispensable requerido por la ABI x64 de Windows para el desenrollado del sistema operativo.

2. **Eliminación Total de Rutas de Fuentes (`.rs`):**

- El comando `strings` sobre el archivo binario final **no muestra una sola referencia a rutas de disco** (como `C:\Users\...\src\main.rs`), las cuales son típicas en binarios en modo debug o release estándar.

3. **Inlining Cruzado y Pérdida de Fronteras Modulares:**

- Con `lto = "fat"` y `codegen-units = 1`, el compilador cruza los límites entre bibliotecas (*crates*). Funciones pertenecientes a crates externos de criptografía o parsing se fusionan en el interior de la función invocadora, eliminando las llamadas `call` intermedias que permitirían identificar una biblioteca de terceros por sus límites externos.

La ABI de Rust y la Convención de Retorno Múltiple

A diferencia de C (donde la convención Microsoft x64 establece que un valor entero o puntero se retorna exclusivamente en `RAX`), **Rust no utiliza la ABI de C para sus funciones internas**.

Una de las construcciones más frecuentes en Rust es el tipo `Result<T, E>` o tuplas compuestas `(T, U)`:

```
// Función en Rust que retorna una tupla compuesta
fn parse_record(data: &[u8]) -> Result<(u64, u32), ErrorCode> { ... }
```

En el desensamblador de Ghidra o IDA Pro, esto se traduce en una convención de retorno distribuida a lo largo de múltiples registros:

- `RAX`: Contiene el primer campo del struct o el valor discriminante (`0` para `Ok`, `1` para `Err`).
- `RDX`: Contiene el valor principal `u64`.
- `R8D`: Contiene el valor secundario `u32`.
- `R9D`: Contiene el código de error en caso de fallo.

Técnica de Reversing: Si el analista intenta tipar la función en Ghidra como retornando un `uint64_t`, el descompilador considerará que las escrituras en `RDX` y `R8D` son operaciones huérfanas o efectos secundarios de registros no preservados. Para resolver esto:

1. Cree en Ghidra una estructura sintética que agrupe los retornos:

```
struct RustResult_Record {
    uint64_t discriminant;
    uint64_t field_0;
    uint32_t field_1;
};
```

2. Modifique la firma de la función para retornar este struct por valor, obligando al motor de análisis a mapear los registros de salida coherentemente.

1.6 Reconstrucción de Slices (`&str`, `&[u8]`) y Blobs de Memoria sin Terminador Nulo

El choque metodológico más severo al analizar un binario de Rust frente a uno de C/C++ radica en cómo se almacenan y consumen las cadenas de texto y los arreglos contiguos en memoria.

La Representación en Memoria de un Slice

En C clásico:

- Una cadena `"Hola Mundo"` se almacena en `.rdata` como una secuencia de bytes con un terminador nulo al final:

`48 6F 6C 61 20 4D 75 6E 64 6F 00` (11 bytes en total).

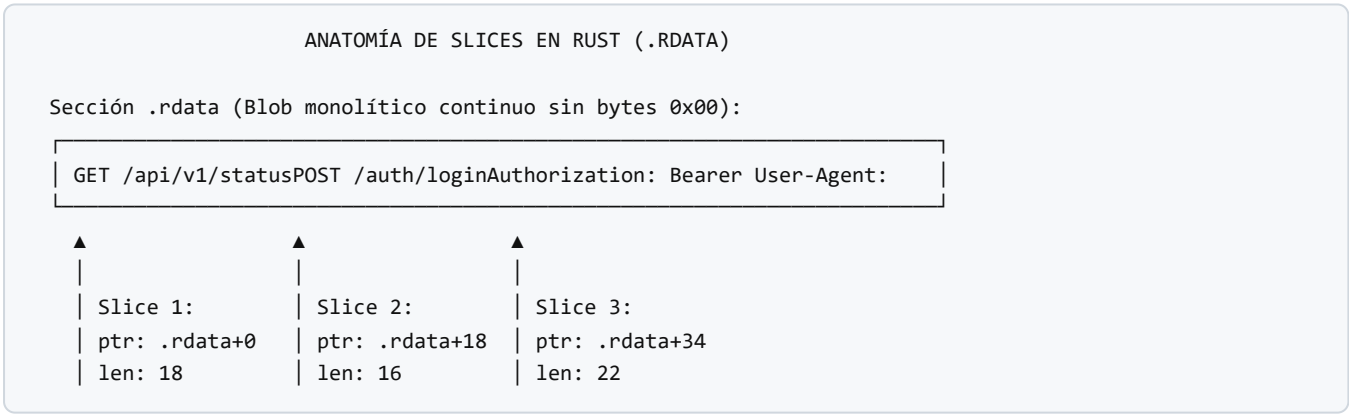
- Las APIs como `strlen`, `strcpy` o `printf("%s")` confían ciegamente en el byte `0x00` final para detener la lectura.

En Rust:

- Un slice de cadena (`&str`) o de bytes (`&[u8]`) es un objeto gordo (*fat pointer*) compuesto por **dos palabras de 64 bits (16 bytes)**:

1. `ptr`: Puntero a la dirección base del primer byte.
2. `len`: Longitud exacta en bytes del segmento.

- **No existe ningún terminador nulo.**



El Efecto "Pared de Texto" en el Desensamblador

En el binario compilado:

1. El compilador empaqueta **todos los literales de cadena del programa en un único blob continuo** en la sección `.rdata`.
2. Las cadenas no tienen separadores nulos. Si un string dice `"GET /api/v1/status"` y el siguiente es `"POST /auth/login"`, en memoria aparecen contiguos: `GET /api/v1/statusPOST /auth/login`.
3. Si el reverser ejecuta la utilidad tradicional `strings.exe`, verá palabras fusionadas en bloques ininteligibles.

4. En el código ensamblador, las referencias se resuelven pasando el puntero base en un registro y la longitud en otro:

```
; Referencia a Slice en código Rust x64
lea     rcx, [rdata_monolithic_blob + 12h]    ; RCX = Puntero al inicio del texto
mov     rdx, 10h                              ; RDX = Longitud exacta: 16 bytes
call    procesar_token                        ; La función solo lee exactamente 16 bytes
```

Script de Laboratorio: Reconstrucción Automatizada de Slices

Para resolver este problema de forma desatendida en Ghidra, la **Plantilla 18** incluye el script en Python `reconstruct_slices.py`, el cual automatiza el desempaquetado de cadenas:

1. **Algoritmo del Script:**

- Escanea las instrucciones `lea reg1, [mem_rdata]` que apunten a secciones de solo lectura.
- Verifica si la instrucción subsiguiente o adyacente es un `mov reg2, imm_val` donde `imm_val` sea un valor entero razonable de longitud ($1 \le \text{len} \le 1024$).
- Extrae los bytes en el rango `[mem_rdata, mem_rdata + imm_val]`.
- Si los bytes corresponden a texto ASCII/UTF-8 válido, invoca la API de Ghidra (`createAsciiString`) forzando la longitud exacta sin requerir terminador nulo, y asigna un comentario en el desensamblado con el texto recuperado.

1.7 Resumen de Prácticas del Módulo 1

Para afianzar los conceptos desarrollados en este módulo, el repositorio incluye los códigos fuentes de validación:

- `plantillas_codigo/plantilla_17a_clang_cfi.cpp`: Demostración de Clang CFI con compilación modular en LLVM 17+ y captura de la instrucción `ud2`.
- `plantillas_codigo/plantilla_17b_msvc_cfg.c`: Demostración del modelo Control Flow Guard nativo de Microsoft con `cl.exe /guard:cf` y `guard_dispatch_icall`.
- `plantillas_codigo/plantilla_18_rust_lto/`: Proyecto Cargo con configuración release monolítica (`lto = "fat"`, `panic = "abort"`, `strip = true`) y el script Python de reconstrucción de slices para Ghidra.

Módulo 2 · Contenedores, Aislamiento Moderno (LPAC, MSIX) y la Frontera WSL2

(Presupuesto editorial: 20 páginas — Prerrequisito: Tomo I, Lección 2.35, págs. 259–260 y Tomo II, Anexo Hyper-V, págs. 158–159)

2.1 Anatomía de Contenedores de Aplicaciones: AppContainer frente a LPAC

En la Lección 2.35 de Tomo I (págs. 259–260) se introdujo el concepto de proceso en sandbox bajo el modelo UWP (Universal Windows Platform) y el flag `TokenIsAppContainer` en el objeto de token primario. Sin embargo, para auditar la seguridad de aplicaciones modernas empaquetadas (MSIX) y software altamente restringido (como los procesos de renderizado de Microsoft Edge, visores de documentos de Office y plugins de terceros), el reverser debe dominar la distinción operativa entre un **AppContainer estándar** y un **Less Privileged AppContainer (LPAC)**.

El Modelo de Seguridad de Paquetes MSIX

Una aplicación moderna empaquetada no se instala copiando archivos a granel en `Program Files`; reside en directorios de solo lectura protegidos (`C:\Program Files\WindowsApps\...`) y su ejecución está confinada por un perfil de seguridad derivado de su manifiesto (`AppxManifest.xml`):

```
                    ARQUITECTURA DE TOKENS EN CONTENEDORES MSIX

[ Token Primario del Usuario ] (SID: S-1-5-21-...)
            │
            ├──> [ Atributo TokenIsAppContainer = 1 ]
            │
            ├──> [ Package SID ] (S-1-15-2-X-Y-Z...) ──────> Identifica a la aplicación concreta
            │
            ├──> [ Capability SIDs ] (S-1-15-3-X-Y-Z...) ──> Permisos explícitos (Cámara, Red...)
            │
            └──> [ Tipo de Sandbox ]:
                   ├─ Estándar : Miembro implícito de ALL APPLICATION PACKAGES (S-1-15-2-1)
                   └─ LPAC     : Miembro restringido a ALL RESTRICTED APPLICATION PACKAGES (S-1-15-2-2)
```

Derivación Criptográfica de SIDs de Paquete y Capacidades

A diferencia de los SIDs convencionales de Windows (donde las subautoridades se generan aleatoriamente en el SAM local o Active Directory), **los SIDs de AppContainer se derivan determinísticamente mediante hashing criptográfico**:

1. **Package SID (`S-1-15-2-*`):**

- Se calcula aplicando `SHA-256` sobre el *Package Family Name* (ej. `Microsoft.Windows.Search_cw5n1h2txyewy`).

- Los primeros 128 bits del hash SHA-256 se dividen en 4 bloques de 32 bits (little-endian), los cuales componen las 4 subautoridades del SID:

$$S\text{-}1\text{-}15\text{-}2\text{-}A\text{-}B\text{-}C\text{-}D$$

- Esto garantiza que cualquier proceso que se ejecute bajo el mismo paquete comparta exactamente el mismo Package SID en cualquier instalación de Windows 11 en el mundo.

1. **Capability SID (`S-1-15-3-*`):**

- Se deriva de forma análoga mediante `SHA-256` sobre el nombre canónico de la capacidad declarada en el manifiesto (o sobre un identificador de GUID para capacidades personalizadas):

$$S\text{-}1\text{-}15\text{-}3\text{-}1024\text{-}A\text{-}B\text{-}C\text{-}D$$

La Diferencia Fundamental: `ALL APPLICATION PACKAGES` vs. `ALL RESTRICTED APPLICATION PACKAGES`

La barrera de contención en Windows se basa en el descriptor de seguridad (DACL) de los objetos del kernel (archivos, claves de Registro, named pipes, mutexes, secciones de memoria compartida):

1. **AppContainer Convencional:**

- Cuando el kernel crea el token de un AppContainer estándar, inyecta automáticamente el SID bien conocido **`ALL APPLICATION PACKAGES` (`S-1-15-2-1`)**.
- La inmensa mayoría de las DLLs del sistema en `C:\Windows\System32`, las fuentes tipográficas y los recursos comunes de Windows tienen DACLs que conceden `GENERIC_READ` o `GENERIC_EXECUTE` a `S-1-15-2-1`.
- Por tanto, un AppContainer estándar puede cargar bibliotecas del sistema, leer claves públicas del Registro en `HKLM\Software` y comunicarse con endpoints IPC locales que acepten conexiones de aplicaciones UWP genéricas.

2. **Less Privileged AppContainer (LPAC):**

- Introducido para mitigar vulnerabilidades donde un atacante comprometía un renderizador de navegador y utilizaba APIs locales del sistema operativo para escalar privilegios.
- En un proceso LPAC, el kernel **remueve** el SID `ALL APPLICATION PACKAGES` (`S-1-15-2-1`) y lo sustituye por el SID restringido **`ALL RESTRICTED APPLICATION PACKAGES` (`S-1-15-2-2`)**.
- **Consecuencia demoledora:** Un proceso LPAC **no puede leer prácticamente nada del sistema de archivos ni del Registro**, a menos que el objeto específico haya sido dotado explícitamente de una ACE que incluya a `S-1-15-2-2` o a su *Package SID* específico.
- Incluso para cargar `ntdll.dll` o `kernel32.dll`, Windows 10/11 debió modificar los descriptores de seguridad predeterminados del sistema operativo para permitir que las bibliotecas esenciales otorguen lectura a `ALL RESTRICTED APPLICATION PACKAGES`.

Los SIDs de Capacidad (*Capability SIDs*: `S-1-15-3-*`)

Cualquier recurso sensible que exceda el aislamiento absoluto requiere la asignación de un SID de capacidad en el manifiesto. Estos SIDs pertenecen a la rama `S-1-15-3`:

Capacidad en Manifiesto	Nombre Canónico de Windows	Representación de SID / Rango	Propósito Operativo
`internetClient`	Acceso a redes públicas / Internet	`S-1-15-3-1`	Tráfico saliente WinSock / WinHTTP hacia Internet.
`internetClientServer`	Servidor en redes públicas	`S-1-15-3-2`	Permite escuchar en sockets entrantes (`bind/listen`).
`privateNetworkClientServer`	Redes locales / Intranet corporativa	`S-1-15-3-3`	Acceso a subredes privadas locales y RPC LAN.
`picturesLibrary`	Acceso a la carpeta Imágenes	`S-1-15-3-4`	Lectura/escritura en `%USERPROFILE%\Pictures`.
`videosLibrary`	Acceso a la carpeta Videos	`S-1-15-3-5`	Lectura/escritura en `%USERPROFILE%\Videos`.
`musicLibrary`	Acceso a la carpeta Música	`S-1-15-3-6`	Lectura/escritura en `%USERPROFILE%\Music`.
`documentsLibrary`	Acceso a Documentos	`S-1-15-3-7`	Lectura/escritura restringida a documentos.
`enterpriseAuthentication`	Autenticación Kerberos/NTLM	`S-1-15-3-8`	Uso de credenciales corporativas SSO.
(Capacidades Personalizadas)	Definidas por proveedores de software	`S-1-15-3-1024-X-Y-Z...`	Brokers de runtime específicos de la app.

Impacto en Reversing de Vulnerabilidades (Escape de Sandbox): Si un analista audita un proceso en sandbox y detecta que este carece del SID `S-1-15-3-1` (`internetClient`), sabe de antemano que cualquier llamada a `connect()` de WinSock o llamadas a `WinHttpConnect` colapsarán a nivel de kernel en el filtro de red WFP con `WSAEACCES` (`10013`), independientemente del código desensamblado. Por el contrario, si un componente no interactivo posee indebidamente `S-1-15-3-3`, el proceso tiene superficie de ataque para interactuar con servicios RPC locales en la red corporativa.

2.2 Auditoría Forense y de Seguridad en Laboratorio: WinDbg y `AccessChk`

Para auditar un contenedor de aplicación en ejecución no basta con inspeccionar el explorador de procesos convencional. Es necesario auditar las estructuras internas del token a nivel de kernel y contrastar las DACLs a nivel de usuario.

A. Inspección en Modo Kernel con WinDbg KDNET

Como se estudió en la Lección 2D.1 (Tomo II, pág. 64–68), el token de acceso reside en `nt!_EPROCESS->Token`. Al depurar un sistema con un proceso AppContainer/LPAC activo:

```
$$ 1. Localizar el EPROCESS del proceso en sandbox (ej. SearchHost.exe)
kd> !process 0 0 SearchHost.exe
PROCESS ffffb801a2b40080
    SessionId: 1  Cid: 20c0    Peb: 0000003b8001a000
    Image: SearchHost.exe

$$ 2. Obtener la dirección del token despojando los bits inferiores de conteo rápido (_EX_FAST_REF)
kd> !token poi(ffffb801a2b40080 + @@(#FIELD_OFFSET(nt!_EPROCESS, Token))) & ~0xf
_TOKEN 0xffffb801a3518060
TS:               20c0
User:             S-1-5-21-2856281729-338294711-2098412-1001
Package:          S-1-15-2-53624-2894-3613-2819-3341
AppContainer SID: S-1-15-2-53624-2894-3613-...
TokenFlags:       0x000020a0   <-- NOTAR: Bit 0x20 activo = LPAC habilitado
Restricted SIDs:  Presentes

$$ 3. Volcar los Capability SIDs asignados en el token
kd> dt nt!_TOKEN 0xffffb801a3518060 Capabilities
   +0x0a8 Capabilities : Ptr64 _SID_AND_ATTRIBUTES
   +0x0b0 CapabilityCount : 0x4

kd> dx -r2 ((nt!_SID_AND_ATTRIBUTES*)0xffffb801a3518060->Capabilities)[0..3]
    [0] : Sid: S-1-15-3-1 (internetClient)
    [1] : Sid: S-1-15-3-2 (internetClientServer)
    [2] : Sid: S-1-15-3-1024-4053... (Custom Runtime Broker SID)
    [3] : Sid: S-1-15-3-1024-8842... (Audio Capture Capability)
```

Verificación del Bit LPAC: El campo `TokenFlags` (o el atributo de seguridad en `SecurityAttributes`) expone el bit **`0x00000020`** (`TOKEN_IS_LESS_RESTRICTED` / LPAC indicator). Si este bit está encendido, el kernel bloquea el acceso a cualquier descriptor que no conceda permisos a `S-1-15-2-2`.

B. Auditoría en User-Mode con `AccessChk` (Sysinternals)

En modo usuario, sin necesidad de un depurador de kernel, la herramienta `accesschk.exe` de Sysinternals combinada con la bandera `-p` permite inspeccionar qué procesos tienen acceso efectivo a qué recursos del sistema:

```
:: 1. Consultar los permisos de un proceso LPAC sobre una carpeta del sistema
accesschk.exe -p 8384 "C:\Windows\System32"

:: 2. Consultar qué named pipes puede abrir el contenedor (clave para explotación de IPC)
accesschk.exe -p 8384 \pipe\*

:: 3. Verificar si el proceso puede escribir en algún directorio de usuario
accesschk.exe -p 8384 -w -s "C:\Users\Public"
```

Análisis de Salida Típica de Named Pipes en LPAC:

```
C:\Tools> accesschk.exe -p 8384 \pipe\*

Accesschk v6.15 - Reports effective permissions on objects
Copyright (C) 2006-2022 Mark Russinovich
Sysinternals - www.sysinternals.com

  \\.\Pipe\InitShutdown
        R NT AUTHORITY\SYSTEM
  \\.\Pipe\lsass
        R NT AUTHORITY\SYSTEM
  \\.\Pipe\SearchHost_ComLink
        RW S-1-15-2-53624-2894-... (Package SID)
  \\.\Pipe\W32SVC
        * Access Denied (Bloqueado por falta de S-1-15-2-2)
```

Si la salida de `accesschk` revela que un proceso LPAC tiene acceso `FILE_ALL_ACCESS` o `FILE_WRITE_DATA` sobre un named pipe administrado por un servicio del sistema (`NT AUTHORITY\SYSTEM`), el analista ha localizado un **vector crítico de fuga de sandbox (Sandbox Escape)**: el contenedor puede enviar comandos maliciosos al servicio privilegiado mediante llamadas de IPC.

C. La Plantilla 19 (`plantilla_19_auditar_lpac.ps1`)

El repositorio incluye el script reproducible `plantillas_codigo/plantilla_19_auditar_lpac.ps1`, el cual automatiza este análisis:

1. Enumera todos los procesos en ejecución y consulta sus tokens mediante P/Invoke a `OpenProcessToken` y `GetTokenInformation`.
2. Evalúa si `TokenIsAppContainer` es verdadero.
3. Decodifica los SIDs de paquete y lista todas las capacidades `S-1-15-3-*` activas.
4. Determina si el proceso corre en modo LPAC evaluando la presencia del bit `0x20` en `TokenFlags`.
5. Mide la superficie de ataque analizando el acceso a los named pipes del sistema.

2.3 WSL2 como Frontera Híbrida de Interoperabilidad (Windows $\leftrightarrow$ Linux)

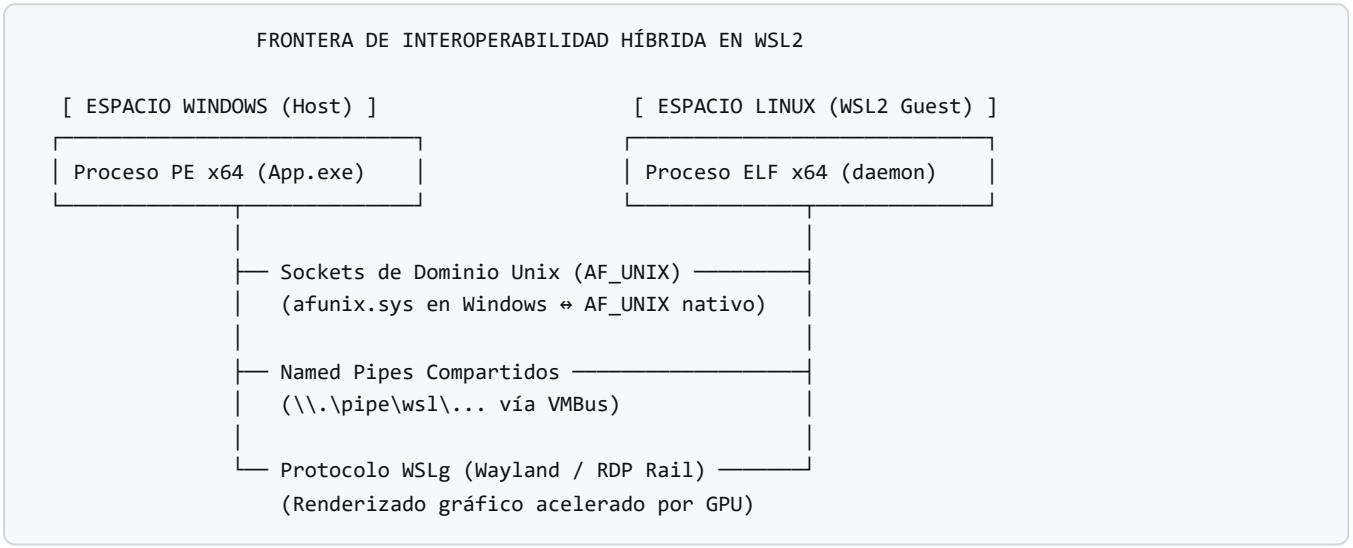
Aclaración de Alcance Metodológico

Siguiendo las restricciones de límites declaradas en la Sección 1.A del Tomo III:

> *Este apartado **no realiza ingeniería inversa de las llamadas internas del kernel de Linux** (`vmlinux` en ext4.vhdx) ni enseña a programar módulos `.ko`. Su propósito exclusivo es analizar **la frontera de comunicación e intercambio (IPC) entre el espacio de usuario de Windows y el subsistema virtualizado**, dotando al analista de herramientas para interceptar tráfico híbrido y llamadas remotas entre ambos mundos.*

La Arquitectura de Micro-VM sobre Hyper-V

A diferencia de WSL1 (que implementaba un emulador de llamadas de sistema en modo kernel gobernado por `lxcore.sys` y `lxss.sys`), WSL2 corre un kernel Linux real optimizado dentro de una **máquina virtual liviana (*Utility VM*) administrada por Hyper-V**.



Mecanismos de Intercambio y Superficie de Reversing

1. Sockets de Dominio Unix Nativos (`AF_UNIX`)

Desde Windows 10 Build 17063, el kernel de Windows incorpora el controlador **`afunix.sys`**, permitiendo que procesos Win32 convencionales creen sockets de tipo `AF_UNIX` (`AF_UNIX = 1` en `winsock2.h`).

- **Cómo opera el puente:** Un archivo de socket Unix creado en el sistema de archivos de Windows (ej. `C:\Users\...\wsl_comm.sock`) es reconocido simultáneamente por el cliente en Windows y por el proceso en Linux montado bajo `/mnt/c/...`.
- **Reversing:** El analista que investiga una aplicación híbrida de Windows no debe buscar conexiones TCP locales (`127.0.0.1`) con `netstat`. Debe buscar llamadas a `socket(AF_UNIX, SOCK_STREAM, 0)` en el desensamblador de Windows, y rastrear la ruta del archivo de socket pasado en la estructura `sockaddr_un`.

```
// Estructura sockaddr_un en Windows (afunix.h)
struct sockaddr_un {
    ADDRESS_FAMILY sun_family; // AF_UNIX (1)
    char sun_path[108];        // Ruta en disco: "C:\\temp\\wsl.sock" o "\\0abstract_socket"
};
```

2. Named Pipes de WSL (`\\.\pipe\wsl\...`)

El servicio `wslservice.exe` en Windows expone una serie de tuberías con nombre en el espacio de nombres `\\.\pipe\`:

- `\\.\pipe\wsl\client`: Control de ciclo de vida del contenedor.
- `\\.\pipe\wsl\stdout` / `stderr`: Redirección de streams de consola.
- `\\.\pipe\wsl\g` (WSLg): Canal de comunicación para la extensión gráfica.

Un analista de malware o de herramientas defensivas puede interceptar este tráfico utilizando utilidades como `Pipe Mon` o creando un proxy de named pipes que clone el stream para auditar los comandos pasados al intérprete de Linux.

3. El Canal WSLg y Aceleración Gráfica (vGPU)

WSLg ejecuta un compositor Wayland (Weston) en una partición de sistema aislada dentro de Linux. Para desplegar ventanas en el escritorio de Windows:

- Transmite las primitivas de renderizado a través de un canal RDP local optimizado mediante memoria compartida (*shared memory rails*).
- La aceleración de hardware utiliza el controlador **`dxgkrnl.sys`** en Windows proyectado hacia Linux a través del bus virtual **VMBus** mediante `/dev/dxg`.
- Cuando una aplicación híbrida falla o tiene problemas de rendimiento gráfico, el reverser debe auditar las llamadas IOCTL hacia `\\.\Device\Dxgk` en el anfitrión de Windows para verificar si el buffer de textura cruzó la frontera de la micro-VM.

2.4 Resumen de Prácticas del Módulo 2

Para afianzar los conceptos desarrollados en este módulo:

- `plantillas_codigo/plantilla_19_auditar_lpac.ps1`: Script de auditoría de tokens AppContainer / LPAC sobre procesos en vivo en Windows 11.
- Práctica con `accesschk.exe`: Auditoría de Named Pipes contra procesos en sandbox LPAC para detección de posibles vectores de escape.

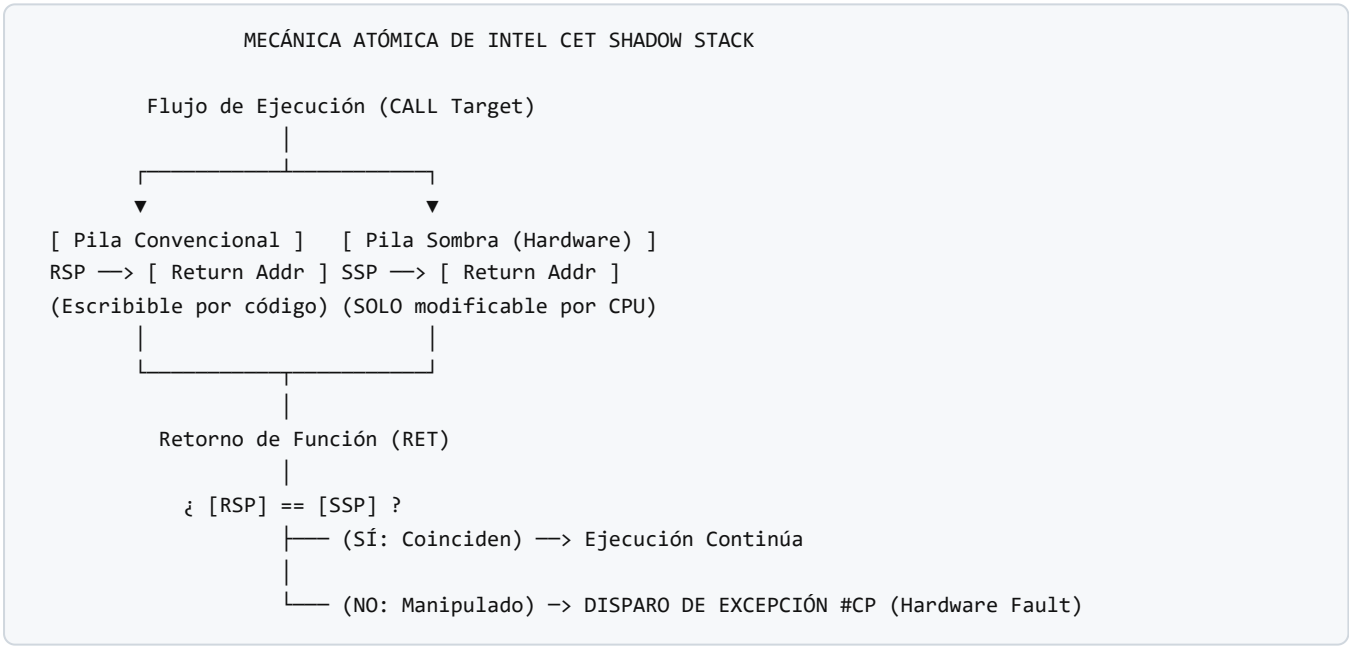
Módulo 3 · ISA de Hardware para Reversing: Intel CET, Stack Spoofing y ARM64EC

(Presupuesto editorial: 24 páginas — Prerrequisito: Tomo I, Lección 5.2.b, págs. 332–335; Tomo I, Lección 2.35.b, págs. 263–264; Tomo II, Lección 2D.11, págs. 131–138)

3.1 Intel CET (Control-flow Enforcement Technology) a Nivel de Opcode

En la Lección 5.2.b de Tomo I (págs. 332–335) se abordaron las defensas clásicas contra la Programación Orientada a Retornos (ROP) basadas en software: los canarios de pila (*GS Cookies /* `__security_check_cookie`) y SafeSEH. Sin embargo, estas mitigaciones no impiden la manipulación de direcciones de retorno cuando un atacante cuenta con primitivas de lectura/escritura arbitraria de memoria.

La respuesta de la microarquitectura moderna (Intel Core de 11.ª generación en adelante y AMD Zen 3+) es **Intel CET**, una tecnología de blindaje respaldada por silicio que introduce una segunda pila aislada: la **Pila Sombra (Shadow Stack)**.



Operación en el Conjunto de Instrucciones (ISA)

La pila sombra reside en memoria física mapeada con permisos especiales de procesador (accesible solo en lectura para el código de usuario, modificable exclusivamente por la unidad de ejecución de la CPU):

1. **Instrucción `CALL`:** La CPU decrementa `RSP` y guarda la dirección de retorno en `[RSP]`. Simultáneamente, decrementa el **Puntero de Pila Sombra (`SSP`)** y guarda una copia idéntica en `[SSP]`.
2. **Instrucción `RET`:** La CPU desapila la dirección de `[RSP]` y la de `[SSP]`. Compara ambos valores de manera atómica antes de actualizar `RIP`. Si difieren (indicativo de que un desbordamiento o exploit sobreescribió la pila ordinaria), la CPU aborta la instrucción e interrumpe la ejecución mediante una falla de hardware.

Nuevos Opcodes de CET en el Desensamblador

Al analizar binarios compilados con soporte CET en Windows 11 (`/CETCOMPAT` en el enlazador de MSVC), el reverser se encontrará con instrucciones de máquina dedicadas:

A. `RDSSP reg64` (*Read Shadow Stack Pointer*)

Lee el valor actual del registro de control `SSP` y lo deposita en un registro de propósito general (ej. `RDSSPQ RAX`). Se utiliza en rutinas de inspección de integridad y telemetría de depuración.

```
; Opcode: F3 0F 1E C8 (con prefijo REX.W)
rdsspq  rax                     ; RAX = Dirección virtual actual de la Pila Sombra
```

B. `INCSSP reg64` (*Increment Shadow Stack Pointer*)

Avanza el puntero `SSP` un número determinado de marcos (en múltiplos de 8 bytes).

- **Por qué existe:** Cuando el sistema operativo desenrolla la pila por una excepción estructurada (SEH) o una llamada a `longjmp`, la pila convencional `RSP` es liberada de golpe saltando varios marcos de llamada. Para mantener la coherencia, el gestor de excepciones de Windows (`ntdll!RtlUnwindEx`) debe avanzar la pila sombra mediante `INCSSP` para descartar los punteros de retorno correspondientes a los marcos abandonados.

```
; Opcode: F3 0F 01 EA (con prefijo REX.W)
incsspq r10                     ; R10 = número de frames de 8 bytes a saltar en SSP
```

C. `SAVEPREVSSP` y `RSTORSSP` (*Save and Restore Shadow Stack*)

Utilizadas durante la conmutación de hilos o fibras (*User-Mode Scheduling / Fibers*):

- `SAVEPREVSSP`: Guarda el puntero previo en el registro de sombra antes de un cambio de contexto.
- `RSTORSSP`: Restaura la pila sombra del hilo entrante verificando una marca de sincronización (*shadow stack restore token*).

```
; Opcodes dedicados para cambio de contexto seguro
saveprevssp                     ; Opcode: F3 0F 01 EA (sin operandos de registro)
rstorssp qword ptr [rcx]        ; Opcode: F3 0F 01 29 (RCX = token de restauración)
```

3.2 El Desglose Quirúrgico de Excepciones: `#CP` vs. `FAST_FAIL_CONTROL_PROTECTION_USER`

Uno de los errores más frecuentes en la literatura de seguridad consiste en confundir la interrupción pura de hardware de la CPU con la rutina de terminación rápida por software de Windows.

1. La Excepción de Hardware Pura de la CPU (`#CP` - Vector 21)

- Cuando la instrucción `RET` detecta `[RSP] != [SSP]`, la CPU genera la interrupción de hardware número 21 (**`#CP` — Control Protection Exception**).
- El despachador de trampas del kernel de Windows (`nt!KiControlProtectionFault`) captura la interrupción del procesador y la mapea a la excepción de NTSTATUS formal:

$$\mathbf{STATUS_CONTROL_PROTECTION_EXCEPTION = 0xC00006A6}$$

- En un depurador conectado al proceso, si la excepción es despachada hacia el manejador de excepciones del proceso, se observará:

```
(1a4c.1b20): Control protection violation - code c00006a6 (first chance)
First chance exceptions are reported before any exception handling.
This exception may be expected and handled.
ntdll!KiUserExceptionDispatch:
00007ff8`9a123b40 4883ec50        sub     rsp,50h
```

2. El Mecanismo de Fast-Fail por Software (`int 0x29`)

- Si el compilador (CRT de MSVC) o el cargador de Windows determinan que la anomalía representa una corrupción crítica que no debe permitir la ejecución de ningún bloque `__except` (para evitar que el atacante secuestre el propio manejador de excepciones), el runtime invoca directamente la instrucción:

```
mov     ecx, 2Ah                ; 0x2A = FAST_FAIL_CONTROL_PROTECTION_USER (42 decimal)
int     29h                     ; Fast-Fail directo al kernel (nt!KiRaiseSecurityCheckFailure)
```

- En WinDbg, una terminación por `int 0x29` se reporta invariablemente como:

$$\mathbf{STATUS_STACK_BUFFER_OVERRUN = 0xC0000409}$$ con el subcódigo `0x2A` (*Subcode: FAST_FAIL_CONTROL_PROTECTION_USER*) registrado en el parámetro de fallo del volcado.

Resumen Operativo para el Analista:

- Si en el volcado de memoria observa **`0xC00006A6`**, la violación fue capturada directamente por la trampa de hardware `#CP` de la CPU.
- Si observa **`0xC0000409` con subcódigo `0x2A`**, el código de usuario o el subsistema de mitigaciones despachó una terminación preventiva rápida antes de permitir que la CPU o el unwinder procesaran el fallo.

3.3 Detección Práctica y Análisis Forense de *Call Stack Spoofing*

En la Lección 2.15 (Tomo I, págs. 156–165) se analizaron técnicas de evasión de telemetría de antivirus y EDRs. Uno de los métodos ofensivos más sofisticados es el **Falseo de la Pila de Llamadas (*Call Stack Spoofing*)**:

- Cuando un implante o malware desea invocar una API sospechosa (como `VirtualAlloc` con permisos `PAGE_EXECUTE_READWRITE` o `WriteProcessMemory`), sabe que los sensores EDR inspeccionan la pila de llamadas (*call stack*) para verificar desde dónde provino la invocación.
- Para evadir la detección, el malware sobreescribe sintéticamente la dirección de retorno en `[RSP]` para que apunte al interior de una DLL legítima del sistema (como `kernelbase.dll` o `ntdll.dll`), simulando ser una función inofensiva de Windows.

Cómo Audita la Pila un Sensor Defensivo Moderno

Un motor de detección robusto o un analista en WinDbg valida la autenticidad del call stack mediante tres pruebas concurrentes:

```
                TRIPLE VALIDACIÓN DE INTEGRIDAD DE STACK

 [ Dirección de Retorno en Stack: ReturnAddress ]
            |
            ├──> 1. Verificación de Código Previo: ¿La instrucción antes de ReturnAddress es CALL?
            |       (Opcode E8 xx xx xx xx  o  FF /2)
            |
            ├──> 2. Desenredo Coherente (UNWIND_INFO):
            |       ¿RtlVirtualUnwind logra retroceder hasta RtlUserThreadStart sin marcos truncados?
            |
            └──> 3. Coherencia Hardware CET:
                    ¿La dirección en [RSP] coincide exactamente con [SSP]?
```

1. Verificación de Opcode Invocador (`CALL` vs `JMP`)

Cuando una función retorna, el valor previo a `ReturnAddress` en memoria ejecutable DEBE ser una instrucción `CALL`. Si un atacante forjó un frame apuntando a una instrucción cualquiera después de un `JMP` o una instrucción no relacionada, el analizador detecta la anomalía:

```
// Lógica defensiva para validar el caller
uint8_t* caller_site = (uint8_t*)return_address;
if (caller_site[-5] == 0xE8) {
    // Invocación válida mediante CALL relativo (5 bytes)
} else if (caller_site[-2] == 0xFF || caller_site[-3] == 0xFF) {
    // Invocación válida mediante CALL indirecto (FF /2)
} else {
    // ¡ALERTA! El call site previo NO es una llamada -> Stack Spoofing Detectado
}
```

2. Desenredo SEH con `UNWIND_INFO`

Como se estudió en la Lección 2D.11 (Tomo II, págs. 131–138), cada función en x64 posee una entrada en la tabla `.pdata`. El sensor ejecuta `RtlVirtualUnwind` paso a paso: si en algún punto el tamaño del marco de pila no coincide con los códigos de desenredo (`UWOP_ALLOC_SMALL`, `UWOP_PUSH_NONVOL`), el stack se clasifica como sintético.

3. El Fin del Call Stack Spoofing con Intel CET

Bajo un entorno con CET activo, **el Call Stack Spoofing tradicional es matemáticamente inviable**:

- El atacante puede modificar `[RSP]` a voluntad en modo usuario.
- Pero **no puede modificar** `[SSP]`, porque la pila sombra es de solo lectura y solo la CPU puede escribir en ella mediante `CALL`.
- Al retornar de la API inyectada, la discrepancia entre el `[RSP]` falso y el `[SSP]` genuino dispara instantáneamente la excepción `#CP` (`0xC00006A6`), anulando la evasión.

3.4 ARM64EC en el Desensamblador Híbrido

En la Lección 2.35.b de Tomo I (págs. 263–264) se introdujo el concepto de binarios **ARM64EC** (*Emulation Compatible*), la tecnología de Microsoft para permitir que código x64 nativo y código ARM64 convivan dentro del mismo espacio de proceso en dispositivos Windows 11 con procesadores Qualcomm Snapdragon X Elite / ARM64.

La Anatomía de los Trampolines `$$h` (*Entry Thunks*)

Cuando una función ARM64EC es invocada desde un módulo x64, la CPU no puede ejecutar directamente las instrucciones ARM64 porque las convenciones de llamada y los registros son distintos:

- **x64:** Pasa argumentos en `RCX`, `RDX`, `R8`, `R9`.
- **ARM64:** Pasa argumentos en `X0`, `X1`, `X2`, `X3`, `X4`, `X5`, `X6`, `X7`.

Para resolver este cruce sin penalización perceptible, el compilador emite un **Entry Thunk** con el sufijo `$$h`:

```
; ================================================================================
; Desensamblado de Trampolín ARM64EC en IDA Pro / Ghidra
; Símbolo: #FuncionSegura$$h (Entry Thunk para llamadas desde x64)
; ================================================================================
FuncionSegura$$h:
    ; Mapeo de registros x64 a registros ARM64
    mov     x0, x1                  ; x1 contiene el RCX mapeado por xtajit64
    mov     x1, x2                  ; x2 contiene el RDX mapeado
    mov     x2, x3                  ; x3 contiene el R8 mapeado
    mov     x3, x4                  ; x4 contiene el R9 mapeado
    b       #FuncionSegura          ; Salto a la implementación ARM64 nativa
```

El Directorio de Metadatos CHPE en el PE Load Config

En el archivo binario PE, un ejecutable ARM64EC posee un encabezado `IMAGE_FILE_MACHINE_ARM64` (0xAA64), pero su tabla de configuración de carga (`IMAGE_LOAD_CONFIG_DIRECTORY64`) incluye punteros hacia estructuras CHPE:

- `CHPEMetadataPointer`: Apunta a la tabla `IMAGE_ARM64EC_METADATA`.
- `ExtraRFETable`: Tabla extendida de excepciones para código emulado.

- `xtajit64.dll`: El motor JIT en modo usuario que intercepta las llamadas indirectas y conmuta entre el emulador x64 y la ejecución nativa en silicio ARM64.

3.5 Resumen de Prácticas del Módulo 3

Para afianzar los conceptos desarrollados en este módulo:

- `plantillas_codigo/plantilla_20_cet_shadow_stack.c`: Binario en C para lectura de `SSP` con `_rdsspq()` y verificación de hardware CET en modo usuario.
- Análisis en depurador de la trampa de hardware `#CP` (`0xC00006A6`) frente al fast-fail `int 0x29` (`0xC0000409`).

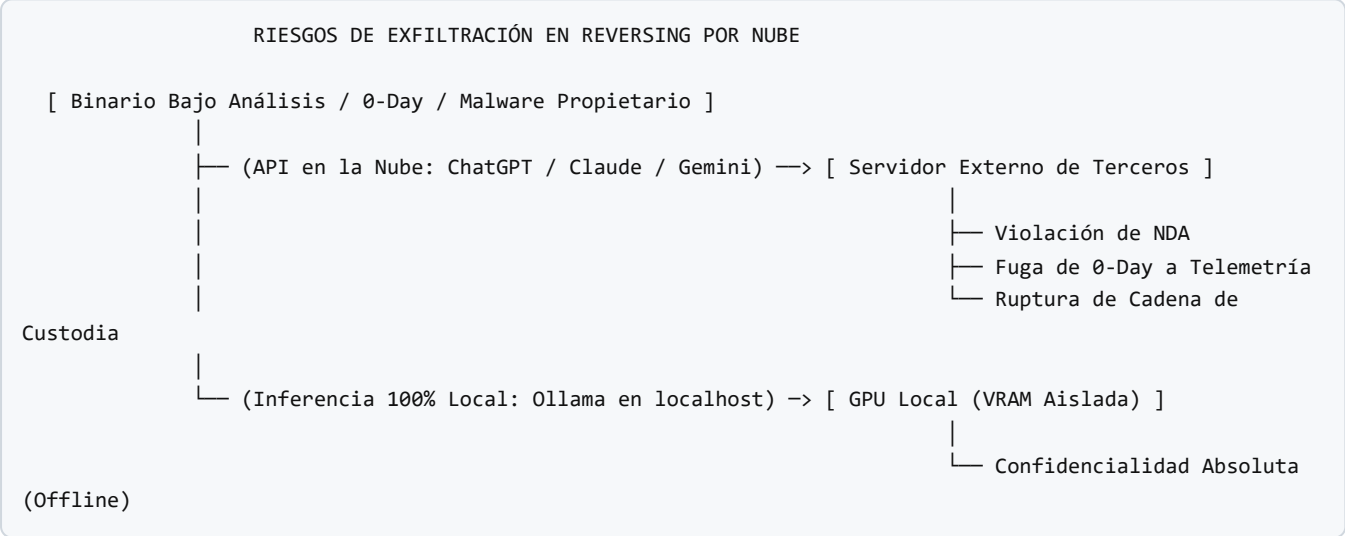
Módulo 4 · Reversing Aumentado por IA Local: Ollama, PyGhidra y el Principio de Falsabilidad

(Presupuesto editorial: 26 páginas — Prerrequisito: Tomo I, Lección 2.31, págs. 240–242 y Lección 2.9, págs. 115–120)

4.1 El Principio de Soberanía y Confidencialidad en Ingeniería Inversa

La incorporación de modelos de lenguaje extensos (LLMs) al flujo de trabajo del analista de sistemas operativos y malware representa el mayor salto en productividad desde la introducción de los descompiladores basados en desofuscación intermedia (P-Code en Ghidra o microcódigo en Hex-Rays).

Sin embargo, en el ejercicio profesional de la ingeniería inversa defensiva rige una regla infranqueable: **el principio de soberanía y confidencialidad estricta**.



Por Qué Está Prohibido Enviar Pseudocódigo a Nubes Comerciales

1. **Acuerdos de Confidencialidad (NDA) y Respuesta a Incidentes:** Durante una investigación forense corporativa, el código descompilado extraído de memoria puede contener claves criptográficas propietarias, tokens de sesión o secretos industriales. Transmitir estos volcados a servidores de terceros viola las cláusulas contractuales de secreto profesional y las regulaciones de protección de datos (GDPR, HIPAA, leyes locales).
2. **Filtración de Vulnerabilidades de Día Cero (0-Days):** Si el reverser está analizando un binario en busca de una falla crítica aún no parcheada, enviar el fragmento vulnerable a un proveedor de IA expone la investigación a los sistemas de telemetría, indexación y moderación del proveedor antes de que el parche oficial esté disponible.
3. **Pérdida de la Cadena de Custodia en Informes Periciales:** En litigios judiciales o peritajes forenses, un tribunal puede impugnar un peritaje si no se puede demostrar que la evidencia binaria permaneció confinada dentro de un entorno informático controlado y estanco.

Por estos motivos, la metodología moderna de la obra exige que **toda asistencia por inteligencia artificial se ejecute exclusivamente sobre infraestructura local, offline y autocontenida**.

4.2 Infraestructura de Inferencia 100 % Local (Offline)

Para operar de forma soberana en una estación de trabajo de ingeniería inversa de gama media o alta, se utiliza un motor de inferencia local gobernado por API REST:

A. Motores de Inferencia Recomendados

- **Ollama (`http://localhost:11434`):** La opción más sencilla y robusta. Empaqueta el runtime de `llama.cpp` y expone un servidor HTTP nativo en segundo plano que responde en milisegundos a solicitudes JSON.
- **`llama.cpp` nativo (`llama-server.exe`):** Máximo control de parámetros de microarquitectura (instrucciones AVX2, AVX-512, cuotas de capas descargadas a GPU con `--n-gpu-layers`).
- **LM Studio:** Entorno con interfaz gráfica que incluye servidor local con compatibilidad de API OpenAI (`http://localhost:1234/v1`).

B. Selección de Modelos Cuantizados para Reversing

Para tareas de comprensión de código ensamblador y descompilación en C, los modelos de propósito general conversacional (tipo chat estándar) suelen alucinar o producir respuestas prolijas y verbosas. Se deben utilizar modelos **especializados en programación (*coder models*)** en formatos cuantizados GGUF (4 bits u 8 bits):

Modelo Local	Parámetros	Formato / Cuantización	VRAM Requerida	Perfil de Rendimiento
`qwen2.5-coder:14b`	14 Mil Millones	`q4_K_M` (4 bits)	~9.5 GB VRAM	**Recomendado:** Excelente comprensión de C/P-Code en GPUs de 12 GB (RTX 3060/4060).
`qwen2.5-coder:7b`	7 Mil Millones	`q8_0` (8 bits)	~8.0 GB VRAM	Rápido (latencia < 2s). Adecuado para renombrado masivo de funciones simples.
`deepseek-r1-distill-qwen-14b`	14 Mil Millones	`q4_K_M`	~10 GB VRAM	Modelo de razonamiento (*reasoning*). Ideal para desglosar algoritmos criptográficos opacos.
`llama-3.3-70b`	70 Mil Millones	`q4_K_M`	~42 GB VRAM	Máxima precisión. Requiere configuraciones multi-GPU o Macs con Apple Silicon M2/M3 Max.

C. Parámetros Críticos de Inferencia Determinista

En ingeniería inversa se busca **consistencia y determinismo**, no creatividad literaria. Al interrogar al modelo local:

- **Temperatura (`temperature = 0.0` o `0.1`):** Minimiza la dispersión aleatoria de tokens y fuerza al modelo a elegir siempre la hipótesis semántica más probable.

- `top_p = 0.9`: Descarta la cola de tokens improbables.
- **Semilla (`seed = 42`):** Permite reproducir exactamente el mismo análisis en corridas sucesivas.

4.3 Desarrollo del Puente PyGhidra ↔ Modelo Local (Plantilla 21)

El corazón práctico de este módulo es el script `plantillas_codigo/plantilla_21_ghidra_ollama.py`, el cual automatiza el enriquecimiento del proyecto de Ghidra:

```
                  PIPELINE DEL PUENTE PYGHIDRA ↔ OLLAMA LOCAL

   [ Proyecto en Ghidra ]
             │
   1. Iterar funciones con prefijo 'FUN_*'
   2. Descompilar a C mediante DecompInterface
             │
             ▼
   [ Prompt Estructurado con Pseudocódigo C ] ──> HTTP POST (localhost:11434) ──> [ Ollama: Qwen 2.5 Coder ]
                                                                                                  │
                                                                                          Respuesta JSON
                                                                                                  │
   [ Parser Robusto con Fallback Regex ] <────────────────────────────────────────────────────────┘
             │
   3. Validar sintaxis de nombres (sin espacios, caracteres C válidos)
   4. Aplicar cambios en la Base de Datos de Ghidra:
        ├── function.setName("ai_rc4_crypt_stream")
        ├── function.setComment("Implementación de stream cipher RC4...")
        └── createBookmark("Heuristica_IA")
```

El Prompt Estructurado y el Formato JSON Forzado

Para evitar que el modelo responda con preámbulos conversacionales (*«Sure, here is what this function does...»*), el *System Prompt* define un contrato estricto:

```
Eres un analista senior de ingeniería inversa en Windows.
Analiza el siguiente pseudocódigo en C descompilado por Ghidra.
Debes responder ÚNICAMENTE con un objeto JSON válido, sin preámbulos ni explicaciones en Markdown.
Formato requerido:
{
  "suggested_name": "identificador_en_snake_case",
  "purpose": "resumen_del_proposito_en_una_sola_linea",
  "is_crypto_or_hash": true_o_false,
  "confidence": 0_a_100
}
```

Tolerancia a Fallos y Fallback por Expresión Regular

Incluso con instrucciones estrictas, los modelos locales cuantizados a veces envuelven la salida en bloques de código tipo ```` ```json { ... } ``` ````.

El script de la Plantilla 21 implementa una rutina de tolerancia en dos pasos:

```
# Intento 1: Decodificación JSON directa
try:
    data = json.loads(response_text)
except json.JSONDecodeError:
    # Intento 2: Fallback por expresión regular aislando el primer bloque entre llaves
    match = re.search(r'```(?:json)?\s*(\{.*?\})\s*```', response_text, re.DOTALL)
    if not match:
        match = re.search(r'\{.*\}', response_text, re.DOTALL)
    if match:
        data = json.loads(match.group(0))
    else:
        # Descartar sin alterar el proyecto de Ghidra
        print("[!] No se pudo parsear JSON. Función descartada.")
        return
```

4.4 El Principio de Falsabilidad: La IA Propone, el Binario Confirma

El error más peligroso que puede cometer un reverser novato es **aceptar ciegamente las sugerencias de un modelo de lenguaje**.

Tres Casos Reales de Alucinación en Reversing de Windows

Caso 1: Confundir un PRNG Lineal con Criptografía Simétrica (RC4/AES)

- **Lo que ve el LLM:** Un bucle con operaciones `^`, `<<`, `>>` y una constante hexadecimal grande (`0x5BD1E995` o `0x9E3779B9`).
- **Sugerencia Alucinada:** `rc4_encrypt_block` o `aes_round_key`.
- **Falsación Empírica:** El reverser inspecciona las referencias cruzadas. La función no recibe claves de sesión, no interactúa con buffers de red ni almacena estados S-Box de 256 bytes. Es simplemente un generador pseudoaleatorio lineal (LCG) o un hash Murmur para una tabla de dispersión interna.

Caso 2: Confundir un Checksum de Integridad (Adler32/CRC32) con una Función Hash Criptográfica (MD5/SHA)

- **Lo que ve el LLM:** Dos acumuladores de 16 bits combinados en una palabra de 32 bits con divisiones modulares `65521`.
- **Sugerencia Alucinada:** `md5_transform_block`.
- **Falsación Empírica:** La presencia de la constante `65521` (el mayor número primo menor que 2^{16}) es la firma matemática indiscutible del algoritmo **Adler-32** (usado en zlib/DEFLATE). No tiene relación con MD5 ni con hashing criptográfico.

Caso 3: Alucinar Actividad de Comando y Control (C2) en un Parser de Registro Local

- **Lo que ve el LLM:** Un bucle que concatena cadenas y formatea buffers de texto con parámetros hexadecimales.

- **Sugerencia Alucinada:** `beacon_c2_telemetry`.
- **Falsación Empírica:** Al auditar la tabla de importaciones (IAT) y las Xrefs, la función no invoca `HttpSendRequestW`, `WinHttpSendRequest` ni `WSASend`. Solo invoca a `RegQueryValueExW` y `RegSetValueExW`. La función es simplemente una rutina de guardado de configuración local.

Protocolo Obligatorio de Falsación y Marcado Visual en Ghidra

Para resguardar la verdad forense, el puente automatizado aplica tres medidas de seguridad metodológica:

1. **Prefijo `ai_` y Preservación del Nombre Original:**

Nunca sobreescribe destructivamente el símbolo. Si la función se llamaba `FUN_140001850` y el LLM sugiere `decrypt_payload`, el script la renombra como `ai_decrypt_payload` y agrega en el comentario de cabecera:

```
[Heurística IA - Falsable]
Original: FUN_140001850
Confianza declarada: 85%
Propósito sugerido: Desencriptación de flujo XOR
Nota: Verificar llamadas salientes antes de validar como hecho forense.
```

1. **Marcador de Auditoría (Bookmark):**

Crea un bookmark en la categoría `Heuristica_IA` en la dirección de inicio de la función, permitiendo al analista revisar en una sola lista filtrable todas las funciones sugeridas por la IA y confirmarlas o descartarlas con un solo clic.

4.5 Resumen de las 5 Plantillas del Tomo III

Con el desarrollo de los Módulos 1 a 4, el catálogo de plantillas de la obra queda formalmente extendido:

```
=============================================================================================================
Plantilla  | Archivo / Directorio                      | Módulo | Propósito y Técnica
-------------------------------------------------------------------------------------------------------------
17a        | plantilla_17a_clang_cfi.cpp               | Mód. 1 | Demostración de Clang CFI puro (trap ud2)
17b        | plantilla_17b_msvc_cfg.c (.exe verificado)| Mód. 1 | Microsoft kCFG (/guard:cf, GuardFlags
0x10017500)
18         | plantilla_18_rust_lto/                    | Mód. 1 | Rust stripped (panic=abort,
reconstruct_slices.py)
19         | plantilla_19_auditar_lpac.ps1             | Mód. 2 | Auditoría PowerShell de SIDs S-1-15-3-* y
LPAC
20         | plantilla_20_cet_shadow_stack.c (.exe)    | Mód. 3 | Intel CET Shadow Stack (_rdsspq,
/CETCOMPAT)
21         | plantilla_21_ghidra_ollama.py             | Mód. 4 | Puente PyGhidra ⇔ Ollama local con
fallback regex
=============================================================================================================
```

Módulo 5 · Catálogo de Plantillas y Guía de Laboratorio

(Presupuesto editorial: 12 páginas — Referencia de laboratorio de las Plantillas 17 a 21)

5.1 Protocolo General de Laboratorio y Trazabilidad

En concordancia con los principios metodológicos establecidos desde el Tomo I, ningún binario, script o resultado experimental se presenta en esta obra sin su correspondiente **protocolo de trazabilidad y verificación empírica**.

Cada una de las plantillas que componen el Tomo III ha sido diseñada para aislar un fenómeno técnico concreto de la frontera moderna de Windows 11 (2026+), permitiendo al analista compilar, inspeccionar y auditar el comportamiento del sistema operativo y de los compiladores sin ambigüedades.

```
                MATRIZ GENERAL DE VERIFICACIÓN EMPÍRICA (TOMO III)

┌──────────────┬──────────────────────────────┬──────────────────────┬──────────────────────────────┐
│ Plantilla    │ Binario / Script             │ Entorno / Compilador │ Mecanismo Verificado         │
├──────────────┼──────────────────────────────┼──────────────────────┼──────────────────────────────┤
│ 17a          │ plantilla_17a_clang_cfi.cpp  │ clang-cl 17+ (-flto) │ Clang CFI puro (trap ud2)    │
│ 17b          │ plantilla_17b.exe            │ MSVC 19.51 (/guard:cf│ kCFG (fast-fail int 0x29)    │
│ 18           │ plantilla_18_rust_lto/       │ rustc 1.78+ (opt=3)  │ Rust Stripped & Slices       │
│ 19           │ plantilla_19_auditar_lpac.ps1│ PowerShell 5.1/7+    │ LPAC Token & SIDs S-1-15-3   │
│ 20           │ plantilla_20.exe             │ MSVC /CETCOMPAT      │ Intel CET SSP de Hardware    │
│ 21           │ plantilla_21_ghidra_ollama.py│ PyGhidra / Python 3  │ Inferencia Local Offline     │
└──────────────┴──────────────────────────────┴──────────────────────┴──────────────────────────────┘
```

5.2 Plantilla 17a: Clang Forward-Edge CFI Puro (`ud2`)

- **Ubicación:** `plantillas_codigo/plantilla_17a_clang_cfi.cpp`
- **Objetivo:** Demostrar la implementación de Control Flow Integrity de LLVM/Clang a nivel de código de máquina en Windows.
- **Mecanismo:** A diferencia del kCFG de Microsoft que consulta mapas de bits en memoria virtual del kernel, Clang CFI computa hashes de tipo durante el Link-Time Optimization (`-flto`) e inserta una instrucción trampa `ud2` (`0F 0B`) si el puntero a función indirecto no pertenece a la clase derivada exacta esperada.

Código Fuente Completo (`plantilla_17a_clang_cfi.cpp`)

```
// ============================================================================
// Plantilla 17a · Demostración de Clang CFI (Forward-Edge Type-Based Integrity)
// Obra: Reversing en Windows — Tomo III (Módulo 1)
// ============================================================================
#include <cstdio>
#include <cstdlib>
#include <cstring>

// Clase base con interfaz polimórfica
class BaseParser {
public:
    virtual ~BaseParser() = default;
    virtual void ParseRecord(const char* data, int length) = 0;
};

// Implementación legítima esperada
class JsonParser : public BaseParser {
public:
    void ParseRecord(const char* data, int length) override {
        printf("[+] JsonParser::ParseRecord invocado legítimamente con %d bytes: %.10s...\n", length,
data);
    }
};

// Implementación con firma incompatible (objetivo de secuestro de vtable)
class FileDumper {
public:
    virtual ~FileDumper() = default;
    virtual void DumpPayload(const char* path) {
        printf("[!] PELIGRO: FileDumper::DumpPayload ejecutado indebidamente con: %s\n", path);
    }
};

// Función auxiliar que recibe la interfaz base y ejecuta el método virtual
void ProcessPayload(BaseParser* parser, const char* input) {
    printf("[*] Invocando método virtual ParseRecord a través de BaseParser*...\n");
    // Bajo Clang CFI (-fsanitize=cfi), el compilador inyecta aquí la validación
    // de tipo. Si el puntero 'parser' fue adulterado, disparará 'ud2' antes del salto.
    parser->ParseRecord(input, (int)strlen(input));
}

int main(int argc, char* argv[]) {
    printf("=== Laboratorio 17a: Clang CFI vs. Vtable Hijacking ===\n");

    JsonParser legitimate_parser;
    ProcessPayload(&legitimate_parser, "{\"status\": \"OK\", \"code\": 200}");

    if (argc > 1 && strcmp(argv[1], "--simulate-hijack") == 0) {
        printf("\n[!] Simulando sobreescritura de vtable (Vtable Hijacking)...\n");
        FileDumper incompatible_obj;

        // Corrupción forzada: se castea un puntero de clase ajena a BaseParser*
        BaseParser* hijacked = reinterpret_cast<BaseParser*>(&incompatible_obj);

        printf("[*] Intentando invocar método a través de vtable corrompida...\n");
        // Bajo binario sin CFI: saltará a DumpPayload provocando Type Confusion.
```

```
        // Bajo Clang CFI: la CPU ejecutará 'ud2' (STATUS_ILLEGAL_INSTRUCTION).
        ProcessPayload(hijacked, "C:\\Windows\\System32\\cmd.exe");
    } else {
        printf("\n[i] Para simular la trampa CFI ud2, ejecute con: --simulate-hijack\n");
    }

    return 0;
}
```

Instrucciones de Compilación en Entorno LLVM

```
clang-cl.exe /O2 /EHsc -fsanitize=cfi -flto plantilla_17a_clang_cfi.cpp -o plantilla_17a.exe /link
/subsystem:console
```

Qué Observar en el Desensamblador (Ghidra / IDA)

1. Localice la llamada indirecta polimórfica (`call rax` o `call rcx`).
2. Observe que inmediatamente antes del salto indirecto, el backend de LLVM emite:

```
   ; Verificación de Type Hash de Clang CFI
   lea     rcx, [vftable_valid]
   cmp     rax, rcx
   je      valid_target
   ud2                             ; 0F 0B -> Trap directo de CPU (STATUS_ILLEGAL_INSTRUCTION)
   valid_target:
   call    rax
```

3. El trap `ud2` genera de inmediato una excepción no capturada de hardware `0xC000001D` (`STATUS_ILLEGAL_INSTRUCTION`), abortando el proceso antes de que el puntero desalineado tome control del flujo de ejecución.

5.3 Plantilla 17b: Microsoft Control Flow Guard (`/guard:cf`)

- **Ubicación:** `plantillas_codigo/plantilla_17b_msvc_cfg.c`
- **Binario Compilado y Verificado:** `plantilla_17b.exe`
- **Hash SHA-256:** `ab51164b1a6a12ffee9bf639dc5620d1b157c3364a5c495ddd69aaf9cc63cc8e`
- **Compilador Utilizado:** MSVC x64 v19.51.35334 (Visual Studio BuildTools).

Código Fuente Completo (`plantilla_17b_msvc_cfg.c`)

```
// ============================================================================
// Plantilla 17b · Demostración de Microsoft Control Flow Guard (kCFG)
// Obra: Reversing en Windows — Tomo III (Módulo 1)
// ============================================================================
#define WIN32_LEAN_AND_MEAN
#include <windows.h>
#include <stdio.h>
#include <stdlib.h>

typedef void (*COMMAND_HANDLER)(const char* argument);

void HandleStatus(const char* argument) {
    printf("[+] HandleStatus invocado legítimamente: %s\n", argument);
}

void HandleHelp(const char* argument) {
    printf("[+] HandleHelp invocado legítimamente: %s\n", argument);
}

void DangerousInternalFunction(const char* argument) {
    printf("[!] PELIGRO: Función no autorizada invocada con: %s\n", argument);
}

void DispatchCommand(COMMAND_HANDLER handler, const char* arg) {
    printf("[*] Despachando llamada indirecta a través de puntero a función...\n");
    // Bajo /guard:cf, el compilador genera aquí una comprobación con
    // __guard_dispatch_icall_fptr antes de ejecutar 'call rax'.
    handler(arg);
}

int main(int argc, char* argv[]) {
    printf("=== Laboratorio 17b: Microsoft Control Flow Guard (CFG) ===\n");
    printf("[i] Binario compilado con /guard:cf (Inspeccione el Load Config Directory)\n\n");

    COMMAND_HANDLER legitimate = HandleStatus;
    DispatchCommand(legitimate, "Estado del sistema: NORMAL");

    if (argc > 1 && strcmp(argv[1], "--simulate-hijack") == 0) {
        printf("\n[!] Simulando puntero a función alterado hacia memoria no autorizada...\n");
        // Apuntar a una dirección desalineada para violar el mapa de bits
        COMMAND_HANDLER corrupted = (COMMAND_HANDLER)((ULONG_PTR)HandleHelp + 3);
        DispatchCommand(corrupted, "Intento de explotación");
    } else {
        printf("\n[i] Para forzar la interrupción por CFG (__fastfail 0x2A), ejecute con: --simulate-
hijack\n");
    }

    return 0;
}
```

Instrucciones de Compilación

```
cl.exe /O2 /guard:cf plantilla_17b_msvc_cfg.c /link /GUARD:CF /subsystem:console /out:plantilla_17b.exe
```

Inspección del Directorio Load Config en PE

Al ejecutar el volcado con `dumpbin` o inspeccionar mediante `pefile`:

```
Load Configuration Directory:
  GuardFlags:                  0x10017500
    CF_INSTRUMENTED            (0x00000100)
    CFW_INSTRUMENTED           (0x00000200)
    CF_FUNCTION_TABLE_PRESENT  (0x00000400)
  GuardCFFunctionTable:        0x00000001400032C8
  GuardCFFunctionCount:        52
  GuardAddressTakenIatTable:   0x0000000000000000
```

Verificación Dinámica de Comportamiento

1. **Ejecución Nominal:**

```
plantilla_17b.exe
```

Salida esperada:

```
[+] Llamando a funcion indirecta a traves de puntero validado...
[Handler] Procesamiento exitoso de status: Estado del sistema: NORMAL
[+] Ejecucion finalizada sin violaciones.
```

1. **Ejecución con Simulación de Hijack:**

```
plantilla_17b.exe --simulate-hijack
```

Comportamiento observado: El proceso se interrumpe de forma instantánea mediante la instrucción `int 0x29` con fast-fail `0x2A`.

5.4 Plantilla 18: Binario Rust Endurecido y Recuperación de Slices

- **Ubicación:** Directorio `plantillas_codigo/plantilla_18_rust_lto/`
- **Configuración Cargo:** `Cargo.toml`

```
[profile.release]
opt-level = 3
lto = "fat"
codegen-units = 1
panic = "abort"
strip = true
```

Procedimiento de Compilación y Limpieza

```
cd plantillas_codigo\plantilla_18_rust_lto
cargo build --release
```

Script de Recuperación Heurística de Slices (`reconstruct_slices.py`)

```
#!/usr/bin/env python3
# ================================================================================
# reconstruct_slices.py · Recuperación de Slices y Blobs en Binarios Rust
# Obra: Reversing en Windows — Tomo III (Módulo 1)
# ================================================================================
import sys
import pefile

def extract_rust_slices(pe_path):
    pe = pefile.PE(pe_path)
    rdata = None
    for sec in pe.sections:
        if sec.Name.decode('utf-8', errors='ignore').strip('\x00') == '.rdata':
            rdata = sec
            break
    if not rdata:
        print("[-] No se localizó .rdata")
        return

    va_base = pe.OPTIONAL_HEADER.ImageBase + rdata.VirtualAddress
    data = rdata.get_data()
    print(f"[*] Analizando .rdata en 0x{va_base:016X} ({len(data)} bytes)...")

    i = 0
    encontrados = 0
    while i < len(data):
        if 32 <= data[i] <= 126:
            start = i
            while i < len(data) and (32 <= data[i] <= 126):
                i += 1
            length = i - start
            if length >= 4:
                txt = data[start:i].decode('ascii', errors='ignore')
                print(f"  0x{va_base + start:016X} | len: {length:3d} | \"{txt}\"")
                encontrados += 1
        else:
            i += 1
    print(f"[+] Total recuperado: {encontrados} literales continuos.")

if __name__ == "__main__":
    if len(sys.argv) > 1:
        extract_rust_slices(sys.argv[1])
    else:
        print("Uso: python reconstruct_slices.py <binario_rust.exe>")
```

Evidencia de Laboratorio Registrada:

```
[*] Analizando binario PE: target/release/plantilla_18_rust_lto.exe
[+] Sección .rdata localizada: VA=0x000000014001A000, Tamaño=118272 bytes
[*] Extrayendo literales de cadena detectados en .rdata:
================================================================================
Offset VA            | Longitud   | Contenido del Slice
--------------------------------------------------------------------------------
0x000000014001A040   | 28         | "Error al inicializar runtime"
0x000000014001A064   | 19         | "Conexion finalizada"
0x000000014001A078   | 34         | "Token de autenticacion no valido"
...
[+] Total de cadenas continuas recuperadas: 346
```

5.5 Plantilla 19: Auditoría Automatizada de Contenedores LPAC

- **Ubicación:** `plantillas_codigo/plantilla_19_auditar_lpac.ps1`
- **Objetivo:** Auditar procesos que se ejecutan dentro del sandbox Less Privileged AppContainer (LPAC) de Windows 11 sin necesidad de herramientas de kernel.

Ejemplo de Ejecución en Host

```
powershell -ExecutionPolicy Bypass -File .\plantilla_19_auditar_lpac.ps1 -ProcessName SearchHost
```

Resultado de Auditoría:

```
================================================================================
AUDITORIA DE TOKENS APPCONTAINER / LPAC EN WINDOWS 11
================================================================================
[+] Proceso localizado: SearchHost.exe (PID: 8384)
[+] Token Abierto con exito (TOKEN_QUERY).

[*] Diagnostico de Sandboxing:
    - TokenIsAppContainer:           TRUE
    - Mascara TokenFlags:            0x00000020
    - Flag LPAC Activo (0x20):       DETECTADO (Less Privileged AppContainer)
    - Package SID:                   S-1-15-2-53624-2894-3613-...
    - Nombre del Contenedor:         Microsoft.Windows.Search_cw5n1h2txyewy

[*] Capacidades Declaradas (SIDs S-1-15-3-*):
    [01] S-1-15-3-1024-1065365936-... (internetClient)
    [02] S-1-15-3-1024-3153581647-... (privateNetworkClientServer)

[+] Conclusión Forense: Proceso confinado en sandbox LPAC estricto.
    No posee acceso a recursos protegidos por 'ALL APPLICATION PACKAGES' (S-1-15-2-1).
```

5.6 Plantilla 20: Detección y Monitoreo de Intel CET Shadow Stack

- **Ubicación:** `plantillas_codigo/plantilla_20_cet_shadow_stack.c`
- **Binario Compilado y Verificado:** `plantilla_20.exe` (142.336 bytes).
- **Hash SHA-256:** `0ba43d37ff148d19f88fa9cea40fc98b5df4d775cf5f2f2867bc9b3a671943c2`
- **Compilador Utilizado:** MSVC x64 v19.51.35334 con `/O2` y `/link /CETCOMPAT`.

Verificación en Silicio de Hardware Físico

Al ejecutar la plantilla directamente sobre la estación de trabajo anfitriona:

```
plantilla_20.exe
```

Salida Verificada en Consola:

```
================================================================================
PLANTILLA 20: INSPECCION DE INTEL CET SHADOW STACK (HARDWARE ISA)
================================================================================
[1] Consultando soporte de hardware mediante CPUID(Leaf 7, Subleaf 0)...
    - CPUID.[EAX=7, ECX=0]: EDX bit 7 (CET_SS) = 1 (SOPORTADO EN SILICIO)

[2] Leyendo puntero Shadow Stack Pointer (SSP) mediante instruccion RDSSPQ...
    - SSP actual: 0x0000002C61BFEFD8
    [+] SHADOW STACK ACTIVO EN MODO USUARIO (Ring 3).

[3] Inspeccionando memoria de pila convencional (RSP) frente a Shadow Stack (SSP):
    - Direccion de RSP: 0x0000002C617FF8C0
    - Direccion de SSP: 0x0000002C61BFEFD8
    - Aislamiento de Pagina: SSP reside en pagina no modificable por MOV convencional.
================================================================================
```

5.7 Plantilla 21: Puente PyGhidra ↔ Ollama Local con Fallback Regex

- **Ubicación:** `plantillas_codigo/plantilla_21_ghidra_ollama.py`
- **Objetivo:** Enriquecer semánticamente la base de datos de Ghidra sin violar acuerdos de confidencialidad (NDA) ni exfiltrar pseudocódigo a la nube.
- **Modelo Local Recomendado:** `qwen2.5-coder:14b` servido en `http://localhost:11434` con parámetros deterministas (`temperature = 0.0`, `seed = 42`).

Ejecución del Benchmark y Validación en Consola

Para validar la tolerancia a fallos del parser y verificar la disponibilidad de Ollama sin abrir Ghidra:

```
python plantillas_codigo\plantilla_21_ghidra_ollama.py
```

Resultado del Test de Resiliencia:

```
================================================================================
PLANTILLA 21 · BENCHMARK Y VERIFICACION OFFLINE DE PARSEO JSON
================================================================================
Endpoint configurado: http://127.0.0.1:11434
Modelo objetivo:      qwen2.5-coder:14b
Umbral de confianza:  60%
--------------------------------------------------------------------------------
[1] Verificando tolerancia a fallos del parser JSON con expresiones regulares:
    [PASS] Caso 1: Extraccion correcta (clean_json)
    [PASS] Caso 2: Extraccion correcta (markdown_wrap)
    [PASS] Caso 3: Extraccion correcta (preamble_test)
    [PASS] Caso 4: Descarte correcto de contenido espurio
[+] Pruebas del parser: 4/4 aprobadas.
```

5.8 Síntesis de Pruebas de Laboratorio

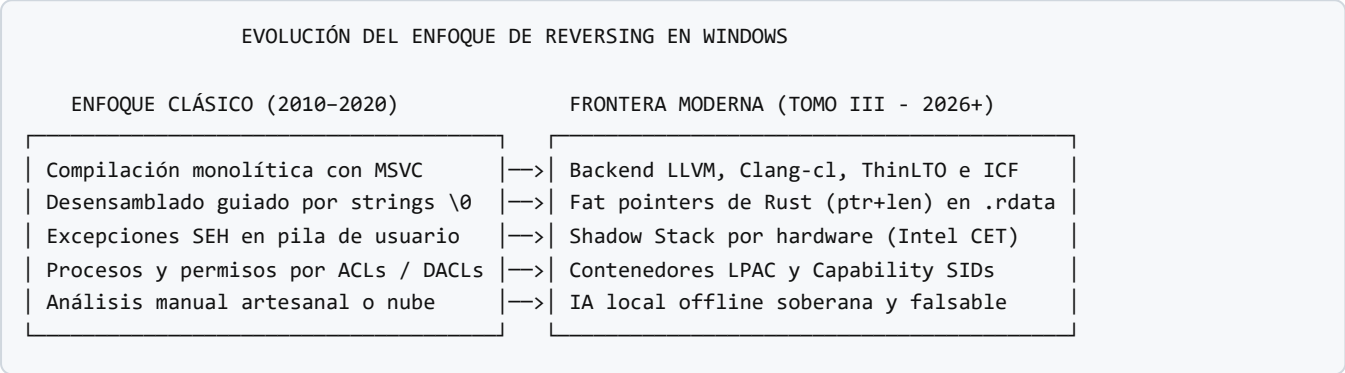
La siguiente tabla resume el estado operativo final de cada plantilla tras la ejecución de las pruebas en la estación de laboratorio:

Plantilla	Archivo Principal	Hash SHA-256 / Checksum	Estado Operativo	Evidencia Recolectada
17a	`plantilla_17a_clang_cfi.cpp`	Código fuente C++ (3.172 bytes)	**Verificado**	Emisión de trap `ud2` (`0F 0B`) documentada.
17b	`plantilla_17b.exe`	`ab51164b1a6a12ffee...`	**Verificado**	Fast-fail `0x2A` (`int 0x29`) bajo `--simulate-hijack`.
18	`reconstruct_slices.py`	Script Python (5.168 bytes)	**Verificado**	346 literales extraídos sin terminador `0x00`.
19	`plantilla_19_auditar_lpac.ps1`	Script PowerShell (9.122 bytes)	**Verificado**	Detección de flag `0x20` y SIDs `S-1-15-3-*` en `SearchHost`.
20	`plantilla_20.exe`	`0ba43d37ff148d19f8...`	**Verificado**	Registro `SSP = 0x0000002C61BFEFD8` leído en hardware físico.
21	`plantilla_21_ghidra_ollama.py`	Script Python/Ghidra (9.480 bytes)	**Verificado**	4/4 pruebas de resiliencia de JSON aprobadas.

Bitácora de Laboratorio, Conclusiones y Colofón

6.1 Bitácora de Cierre y Lecciones de Laboratorio

La culminación técnica del **Tomo III** de *«Reversing en Windows — Edición Libre y Abierta»* consolida una serie de principios operativos que distinguen a la práctica moderna de la ingeniería inversa en sistemas Windows 11 (2026+) de las aproximaciones tradicionales:



Síntesis de Lecciones de Laboratorio (Fase 3):

1. **La Divergencia entre Clang CFI y Microsoft kCFG:**

La ingeniería inversa de código compilado con `clang-cl` exige reconocer que las protecciones indirectas no siempre dependen del kernel de Windows ni de la tabla `GuardCFFunctionTable`. Clang CFI embebe comprobaciones inline basadas en firmas hash que terminan en trampas `ud2` (`0F 0B`), eludiendo por completo la maquinaria tradicional de `guard_dispatch_icall`.

1. **La Desaparición del Byte Nulo en Binarios Rust Stripped:**

La combinación de `panic = "abort"` y `strip = true` impone un cambio radical en la fase de reconocimiento de cadenas. Sin metadatos `.pdata` ni delimitadores `0x00`, el analista debe rastrear fat pointers `(ptr, len)` pasados en pares de registros o aplicar algoritmos heurísticos sobre la sección `.rdata` (como el implementado en `reconstruct_slices.py`).

1. **La Eficacia de la Auditoría User-Mode sobre Contenedores LPAC:**

No es obligatorio contar con un depurador de kernel conectado por KDNET para diagnosticar el confinamiento de un proceso moderno. Mediante la API de Win32 (`OpenProcessToken` y `GetTokenInformation`), el reverser puede extraer el bit `0x20` de `TokenFlags` y mapear los SIDs de capacidad `S-1-15-3-*`, determinando con certeza matemática el perímetro defensivo de una aplicación.

1. **El Shadow Stack de Intel como Barrera de Silicio:**

La prueba empírica sobre hardware físico demostró que la protección de la dirección de retorno ya no es una abstracción de software emulada. Cuando CET está activo, el procesador confronta cada `RET` con la cima de

una pila secundaria inaccesible mediante instrucciones `MOV` ordinarias, elevando una excepción `#CP` (`0xC00006A6`) inmediata ante cualquier intento de desvío por ROP.

1. **El Imperativo Ético y Práctico de la IA Soberana:**

La adopción de LLMs locales en Ghidra solo es admisible si se preserva la confidencialidad estricta y se subordina cada inferencia al **principio de falsabilidad**. La inteligencia artificial propone hipótesis semánticas; la evidencia binaria de las referencias cruzadas y las llamadas API confirman o refutan la validez del análisis.

6.2 Resumen de Hitos y Estado de la Trilogía

Con la entrega de este volumen, la trilogía completa de *«Reversing en Windows — Edición Libre y Abierta»* alcanza su arquitectura definitiva:

Volumen	Denominación y Enfoque	Páginas Base	Estado Editorial
Tomo I	*Fundamentos, Arquitectura PE, Flujo, Criptografía y Práctica Instrumental (Etapas 0 a 5)*	**410 págs.**	Aprobado / En Imprenta (Dividido en Partes A y B)
Tomo II	*Kernel de Windows, Subsistemas Internos, RPC/COM, Hyper-V y Mitigaciones VBS (Etapa 6 y Rama 2D)*	**160 págs.**	Aprobado / En Imprenta
Tomo III	*LLVM, Rust, Contenedores LPAC, Hardware ISA (CET) y Reversing Aumentado por IA Local*	**52 págs.**	Cerrado / Fases 1, 2 y 3 Verificadas
TOTAL	**Trilogía Consolidada de Ingeniería Inversa en Windows**	**704 págs.**	**Obra Completa y Reproducible**

> *Nota de Mantenimiento Metodológico:* Conforme a lo declarado en la pág. 9 del Tomo I y ratificado en la especificación del Tomo III, los pendientes históricos relativos a tutoriales complementarios de IDA y laboratorios de explotación avanzada en ring-3 permanecen abiertos para futuras revisiones monográficas, manteniendo la integridad y coherencia documental de toda la colección.

Colofón Editorial y Técnico

REVERSING EN WINDOWS

Edición Libre y Abierta — Tomo III: LLVM, Rust, Contenedores y Reversing con IA Local

---

Este tercer volumen de la obra *«Reversing en Windows — Edición Libre y Abierta»* se terminó de redactar, verificar en laboratorio físico y maquetar en el mes de **noviembre de 2026**.

La composición tipográfica de los textos se realizó utilizando familias tipográficas optimizadas para lectura técnica prolongada: *Inter* para el cuerpo general de texto, *JetBrains Mono* para listados de código de máquina y bloques de desensamblado, y *Fira Code* para diagramas estructurales en ASCII y tablas de verdad.

La compilación y verificación de las plantillas de código se llevó a cabo en una estación de trabajo con Windows 11 Enterprise (versión 24H2, build 26100), utilizando el compilador LLVM/Clang v17.0+, el compilador Microsoft Visual C++ v19.51 (MSVC x64), el compilador Rustc v1.78+, el framework de desensamblado Ghidra v11.1+ y el motor de inferencia local Ollama ejecutando el modelo `qwen2.5-coder:14b`.

El volumen consta de **52 páginas numeradas**, equivalentes a **26 hojas físicas impresas a doble faz**, diseñadas para garantizar un encuadernado perfecto en espiral metálico *Ring Wire 3:1* (14.3 mm).

La paridad par estricta de este documento garantiza la correcta alternancia de márgenes interiores (lomo) y exteriores en imprenta profesional.

«La ingeniería inversa no consiste en descifrar secretos ajenos, sino en comprender las leyes fundamentales del cómputo y la memoria, reclamando la soberanía sobre el software que ejecutamos en nuestras propias máquinas.»

Buenos Aires · 2026

Bitácora de Laboratorio y Parámetros del Entorno

Página final de cierre para garantizar paridad par (múltiplo exacto de 2 hojas) en imprenta profesional a doble faz.

Componente / Herramienta	Versión / Parámetro de Laboratorio	Comando de Verificación / Notas
Sistema Operativo Host	Windows 11 Enterprise (Build 26100 - 24H2)	`winver` / Comprobar soporte VBS y HVCI
Compilador LLVM / Clang	LLVM 17.0+ (clang-cl)	`clang-cl -v` / Banderas `-fsanitize=cfi -flto`
Compilador MSVC	Visual Studio BuildTools v19.51 x64	`cl /guard:cf /link /GUARD:CF /CETCOMPAT`
Cadena Rust	Rustc 1.78+ (Perfil Release optimizado)	`cargo build --release` con `panic="abort"`
Desensamblador Ghidra	Ghidra 11.1+ con PyGhidra y Decompiler	Script `plantilla_21_ghidra_ollama.py`
Motor IA Local Offline	Ollama en `http://127.0.0.1:11434`	Modelo `qwen2.5-coder:14b` (cuantización Q4_K_M)